TRƯỜNG: _____

KHOA: _____

BÁO CÁO HỌC PHẦN

Môn học: _____

THƯ VIỆN ẢNH SỐ LĂNG KÍNH

WordPress — Mã nguồn mở và an toàn hệ thống

Nhóm 1

Lớp: _____

Giảng viên: _____

Thành viên	Họ và tên	MSSV
TV1		
TV2		
TV3		
TV4		
TV5		

Tháng 10 năm 2026

Phạm vi và tính trung thực của báo cáo

Báo cáo trình bày bộ mã nguồn tại nhánh huyyhoangg, mốc đối chiếu ban đầu 55dd374; các thay đổi bàn giao tiếp theo chưa được commit. Repo nguồn: https://github.com/huyyhoangg11/bai-tap-nhom-wordpress-gallery. Repo nộp cuối: _____.

Không tìm thấy PDF đề bài hoặc DOCX cũ trong repo tại lần rà soát này. Ma trận yêu cầu sử dụng nội dung yêu cầu do người quản lý cung cấp; cần đối chiếu lại nếu giảng viên phát hành bản đề khác. Thông tin trường, môn học, lớp, giảng viên và danh tính thành viên để trống. WBS là đề xuất, chưa xác nhận cá nhân đã thực hiện công việc.

Bằng chứng được chia thành ba nguồn: kiểm thử LocalWP thật; kiểm thử khôi phục trên môi trường riêng; và log lịch sử đã có. Mỗi nguồn có giới hạn riêng. Một ảnh cấu hình chứng minh trạng thái hiển thị tại thời điểm chụp, không thay thế kiểm thử hành vi. Hai tác phẩm bổ sung trong SQL demo chỉ được tạo trên clone để minh họa quy trình; không được mô tả là dữ liệu đã xuất bản của site chính.

Báo cáo không công bố mật khẩu, token, cookie, URL đăng nhập riêng hoặc danh tính tài khoản thật. Cấu hình cấp phép Wordfence và URL riêng phải thiết lập lại khi cài trên máy khác. Quyền sử dụng từng ảnh mẫu chưa có hồ sơ nguồn/giấy phép đầy đủ; việc có ảnh trong repo không chứng minh quyền tái phân phối công khai.

Mục lục

1 Hệ điều hành mã nguồn mở và góc nhìn ATTT **1**

1.1 Phạm vi so sánh và kiến trúc kernel . . . 1

1.2 Phân quyền Linux và Windows . . . 2

1.3 Quản lý bản vá . . . 2

1.4 GPL, giấy phép thương mại và nghĩa vụ phân phối . . . 3

1.5 Auditability và chuỗi cung ứng . . . 4

2 Website và tùy biến mã nguồn **5**

2.1 Bài toán và tiêu chí nghiệm thu . . . 5

2.2 Môi trường thực hành và kiến trúc . . . 6

2.3 Trang chủ, banner và responsive . . . 6

2.4 Album, chủ đề và tác giả . . . 8

2.5 Tìm kiếm và lightbox . . . 9

2.6 Gửi tác phẩm và vòng đời dữ liệu . . . 10

2.7 Watermark và tối ưu ảnh . . . 13

2.8 Tổ chức code tự viết . . . 16

2.9 Git, thành phần bên thứ ba và license . . . 17

3 ATTT và bảo mật hệ thống **19**

3.1 Mô hình đe dọa và phạm vi . . . 19

3.2 Bảo vệ tài khoản và khôi phục . . . 19

3.3 Hardening ứng dụng và máy chủ . . . 21

3.4 Đánh giá lỗ hổng và lịch sử WPScan . . . 22

3.5 Lập trình an toàn và hồi quy . . . 24

4 Bàn giao, WBS và hướng phát triển **26**

4.1 Phạm vi bộ mã nguồn bàn giao . . . 26

4.2 Khôi phục đã kiểm chứng và khác biệt môi trường . . . 26

4.3 WBS và phân công đề xuất . . . 27

4.4 Hạn chế và hướng phát triển . . . 28

Danh mục hình

2.1 Sơ đồ thiết kế kiến trúc . . . 6
2.2 Trang chủ desktop . . . 7
2.3 Trang chủ mobile . . . 8
2.4 Album và chủ đề . . . 8
2.5 Tìm kiếm không dấu . . . 9
2.6 Lightbox . . . 10
2.7 Form gửi tác phẩm . . . 11
2.8 Thông báo chờ duyệt . . . 11
2.9 Kiểm duyệt trong wp-admin . . . 13
2.10 Watermark trên WebP ảnh mới . . . 14
2.11 Network: WebP . . . 15
2.12 Network: JPEG fallback . . . 15

3.1 Khóa đăng nhập . . . 20
3.2 Cấu hình module bảo mật . . . 21

4.1 Khôi phục demo trên môi trường riêng . . . 27

Danh mục bảng

1.1 Ý nghĩa quyền áp dụng trên website của nhóm . . . 2

2.1 Đối chiếu yêu cầu và chức năng hiện có . . . 5
2.2 Đối chiếu negotiation cho cùng URL ảnh banner . . . 16
2.3 Kiểm kê đầy đủ core, theme và plugin cài trên LocalWP . . . 17

3.1 Đối chiếu trạng thái, cấu hình và hành vi bảo mật . . . 22
3.2 Các lần WPScan và giới hạn đọc kết quả . . . 22
3.3 Cảnh báo cấu hình, bằng chứng và xử lý . . . 23
3.4 Kết quả kiểm thử và mức bằng chứng . . . 25

4.1 WBS đề xuất cho 5 thành viên, khoảng 20% mỗi người . . . 27

Phần 1

Hệ điều hành mã nguồn mở và góc nhìn ATTT

1.1 Phạm vi so sánh và kiến trúc kernel

Tại thời điểm đối chiếu ngày 27/10/2026, ảnh cài đặt LTS mới nhất trên nguồn Canonical là Ubuntu 26.04.1 LTS. Đây là bản cập nhật điểm của nhánh 26.04, không phải phiên bản đang cài trên máy thực hành. Máy của nhóm trả về Ubuntu 24.04.4 LTS trong `/etc/os-release`. Windows 11 được dùng làm đối tượng so sánh kiến trúc và chính sách, không phải môi trường đã chạy website trong đợt kiểm thử này. Không suy diễn rằng mọi hành vi trên Ubuntu 26.04 đã được đo thực nghiệm từ máy 24.04.4. Nhánh 26.04 có hỗ trợ tiêu chuẩn đến năm 2031; các giai đoạn mở rộng có điều kiện dịch vụ/phạm vi gói riêng.[1, 2]

Linux tổ chức bộ nhớ đặc quyền kernel tách khỏi tiến trình ở user space. Ứng dụng như PHP hoặc trình duyệt sử dụng thư viện và system call để yêu cầu kernel mở file, tạo tiến trình hay gửi dữ liệu mạng. Điểm chuyển quyền này cần kiểm tra tham số, con trỏ và quyền của chủ thể yêu cầu; một đường dẫn HTTP không trực tiếp trao quyền kernel cho mã PHP. Linux thường được mô tả là kernel nguyên khối có module: nhiều dịch vụ hệ thống và driver cùng thực thi trong kernel space, trong khi module cho phép nạp thành phần theo nhu cầu mà không biên dịch lại toàn bộ kernel. Khả năng nạp module hữu ích cho phần cứng nhưng cũng tạo bề mặt đặc quyền cao, nên không cấp quyền quản trị máy cho tài khoản vận hành nội dung WordPress.[3, 4]

Windows 11 sử dụng dòng kiến trúc Windows NT, kết hợp kernel, executive và các driver. Ứng dụng chạy ở user mode, tương tác qua các API và dịch vụ hệ thống. Kernel và các thành phần executive phụ trách những chức năng như bộ nhớ, tiến trình, I/O và đối tượng; driver có thể chạy ở kernel mode hoặc user mode tùy loại. Lỗi trong thành phần kernel có thể ảnh hưởng rộng hơn một tiến trình ứng dụng. Cả hai hệ điều hành đều có ranh giới đặc quyền và cơ chế kiểm soát truy cập, vì vậy không nên kết luận Linux an toàn chỉ vì có module hoặc Windows kém an toàn chỉ vì tổ chức executive khác Linux.[5, 6]

Trong kiến trúc website của nhóm, Nginx tiếp nhận request rồi chuyển PHP sang PHP-FPM; MySQL là dịch vụ dữ liệu riêng. Các tiến trình đó không cần chạy bằng root để xử lý bài ảnh. Nếu một plugin bị khai thác ở mức PHP, phạm vi thiệt hại chịu ảnh hưởng bởi quyền filesystem, thông tin DB mà PHP đọc được và các dịch vụ có thể truy cập. Ranh giới kernel vẫn quan trọng, nhưng không thay thế việc kiểm tra nonce, capability và MIME trong ứng dụng. Tách tài khoản vận hành, cập nhật driver/kernel và hạn

chế module ngoài nguồn tin cậy là các lớp kiểm soát bổ trợ.

1.2 Phân quyền Linux và Windows

Trên Linux, UID biểu diễn người dùng; GID cùng các nhóm bổ sung tạo bối cảnh nhóm. Mỗi inode có owner/group và các bit quyền cho owner, group, others. Với file thường, `r` cho đọc dữ liệu, `w` cho sửa nội dung, `x` cho thực thi. Với thư mục, `r` cho liệt kê tên, `x` cho đi xuyên/tra cứu các mục con, còn `w` kết hợp với quyền đi xuyên cho phép tạo hoặc xóa mục trong thư mục. Vì vậy, một file chỉ đọc vẫn có thể bị xóa bởi chủ thể có quyền thích hợp trên thư mục cha; chỉ đổi file về 644 không đủ bảo vệ nếu thư mục chứa nó cho người không tin cậy ghi.

ACL mở rộng cho phép cấp quyền cụ thể cho nhiều UID/GID thay vì chỉ ba lớp truyền thống. Mask ACL giới hạn quyền hiệu lực của các mục liên quan; cần kiểm tra `getfacl` khi kết quả truy cập không khớp phép đọc đơn giản từ `ls-l`. Default ACL trên thư mục có thể ảnh hưởng quyền của file mới, còn umask ảnh hưởng quyền lúc tạo. Chmod một lần không bảo đảm mọi ảnh được plugin sinh về sau đều có cùng quyền. Trong triển khai LocalWP phải đối chiếu cả owner của PHP-FPM, Nginx và đường đi qua các thư mục cha.[7]

Windows dùng SID định danh người dùng/nhóm. Access token gắn với tiến trình hoặc luồng mang SID, nhóm và privilege. Security descriptor của một đối tượng có thể chứa DACL và SACL. DACL gồm ACE cho phép hoặc từ chối truy cập; SACL xác định những trường hợp cần audit, không phải danh sách cấp quyền bổ sung. Inheritance truyền các ACE được đánh dấu xuống đối tượng con. DACL rỗng và không có DACL khác nhau: rỗng không cấp quyền, còn trường hợp không có DACL có thể cho phép truy cập rộng. Cần dùng công cụ quản trị/API phù hợp thay vì diễn giải tất cả bằng mô hình số chmod.[8, 9]

Bảng 1.1: Ý nghĩa quyền áp dụng trên website của nhóm

Đối tượng	Quyền và điều kiện	Ý nghĩa ATTT
Thư mục ứng dụng	755, owner phù hợp tiến trình	Owner quản lý; nhóm/others đi xuyên và đọc, không tự ghi.
File PHP/CSS/JS	644	PHP cần đọc mã; không cần bit thực thi cho từng file PHP qua FPM.
`wp-config.php`	400 thực tế; 440 nếu dùng group phù hợp	Hạn chế đọc secret; phải kiểm tra PHP vẫn đọc được.
Dữ liệu Wordfence	Có file 600	Giữ mức chặt hơn 644; không nới quyền máy móc.

Nguyên tắc chung là quyền tối thiểu: người gửi ảnh chỉ có quyền nội dung cần thiết, còn tiến trình máy chủ chỉ ghi vào vùng vận hành cần thiết. Chmod 777 làm mất ranh giới ghi; chmod đệ quy toàn home/Git có thể phá ứng dụng khác. Với LocalWP, các dịch vụ chạy cùng tài khoản desktop nên mô hình cách ly còn hạn chế; kết quả quyền local không tự là cấu hình production tối ưu.

1.3 Quản lý bản vá

APT quản lý gói, dependency và phiên bản qua kho cấu hình trên Ubuntu. Thông tin kho có chữ ký giúp xác nhận nguồn và tính toàn vẹn của metadata; cần giữ key/kho đáng tin, kiểm tra nguồn gói và tránh thêm PPA không cần thiết. `unattended-upgrades` có thể tự áp dụng các cập nhật được chính sách cho

phép. Quản trị viên vẫn cần đọc log, theo dõi cập nhật bị giữ lại và lên lịch reboot khi thành phần đang chạy chưa dùng bản mới. Bản vá cài trên đĩa chưa đồng nghĩa kernel hoặc dịch vụ đang chạy đã được thay thế.[10]

Windows Update cung cấp cơ chế phân phối cập nhật hệ điều hành. Các chính sách cho máy tổ chức có thể quản lý thời điểm nhận bản cập nhật, vòng triển khai và trải nghiệm khởi động lại qua Group Policy hoặc MDM, tùy edition. Phương pháp triển khai theo nhóm thử nghiệm rồi mở rộng giúp phát hiện lỗi tương thích trước khi ảnh hưởng toàn hệ thống. Hoãn cập nhật cần thời hạn và giám sát; hoãn vô thời hạn biến một biện pháp kiểm soát ổn định thành tồn đọng lỗ hổng.[11]

Vòng đời Windows 11 phụ thuộc edition và bản feature: nguồn Microsoft công bố chu kỳ hỗ trợ thông thường 24 tháng cho Home/Pro và 36 tháng cho Enterprise/Education; LTSC có lịch riêng. Vì vậy phải tra đúng phiên bản thực tế thay vì nói mọi Windows 11 cùng ngày hết hỗ trợ. Sau cài bản vá, cần xác nhận build đang chạy, reboot khi cần và chuẩn bị phương án gỡ bản cập nhật/phục hồi đã thử, tương tự việc kiểm tra kernel/dịch vụ sau cập nhật trên Ubuntu.[12]

Quy trình phù hợp với website của nhóm gồm kiểm kê phiên bản; theo dõi thông báo chính thức; sao lưu file, DB và template LocalWP; thử trên clone; chạy luồng upload–duyệt–hiển thị; sau đó mới cập nhật môi trường sử dụng. Kế hoạch rollback phải xác định rõ phục hồi riêng gói, template hay DB. Khi schema thay đổi, khôi phục chỉ code có thể không tương thích DB đã nâng cấp. Khi hỏng rewrite WebP, phục hồi đúng template hiệu quả hơn phục hồi toàn bộ database.

Vá Ubuntu không tự vá runtime nằm trong LocalWP: PHP/Nginx/MySQL được LocalWP quản lý riêng. WordPress core, Astra và các plugin cũng có vòng phát hành độc lập. Mỗi lớp cần kiểm kê và kiểm tra lại. Trong đợt này không nâng hàng loạt phiên bản để làm đẹp kết quả scanner. Công cụ nhận diện phiên bản chỉ cung cấp đầu vào đánh giá; bản vá cần đối chiếu advisory và điều kiện ảnh hưởng, không suy CVE từ một chuỗi số.

1.4 GPL, giấy phép thương mại và nghĩa vụ phân phối

Linux kernel được công bố theo GPL-2.0-only ở cấp tổng thể, có ngoại lệ syscall và quy tắc cho từng file tương thích. Đây không phải tuyên bố mọi gói trong Ubuntu đều cùng GPL: thư viện, công cụ và tài nguyên có thể mang GPL các phiên bản khác, LGPL, BSD, MIT hoặc giấy phép khác. Khi phân phối, cần xem đúng giấy phép của thành phần và hình thức phân phối, giữ thông báo tác quyền, điều kiện kèm theo và đáp ứng nghĩa vụ cung cấp mã nguồn tương ứng khi áp dụng. Việc chương trình user space gọi syscall không tự làm mọi chương trình đó trở thành GPL.[13, 14]

Windows 11 được cung cấp theo điều khoản phần mềm sở hữu độc quyền; quyền cài đặt, chuyển giao và sử dụng phụ thuộc edition, kênh OEM/retail/volume và hợp đồng tương ứng. Người dùng không mặc nhiên có quyền sửa rồi tái phân phối mã nguồn Windows như đối với Linux kernel. Phần mềm mã mở có thể được bán hoặc cung cấp dịch vụ thương mại; thu phí không làm nó tự mất tính mã mở. Ngược lại, có thể tải một phần mềm không mất tiền không đồng nghĩa người dùng được quyền sửa và phân phối mã nguồn.[15]

Đối với Lăng Kính, file LICENSE gốc MIT mang thông báo tác quyền hiện hữu được giữ nguyên. Child theme và module bảo mật khai báo GPL-2.0-or-later ở phạm vi thành phần của chúng; không áp MIT gốc để đổi giấy phép Astra/WordPress/plugin. Image Watermark bản đã cài khai báo MIT; Wordfence khai báo GPL-3.0-or-later. Giấy phép mã không tự cấp quyền dùng ảnh, font hay nhận diện thương hiệu.

Bàn giao học phần cần kèm bảng kiểm kê và giới hạn quyền ảnh chưa được xác nhận, thay vì cam kết mọi tài sản đều do nhóm sở hữu.

1.5 Auditability và chuỗi cung ứng

Khả năng đọc source cho phép kiểm tra đường đi dữ liệu, rà dependency, tái hiện lỗi và đề xuất bản sửa. Lỗi Pass Thru của dự án minh họa ích lợi này: có thể đối chiếu phần đối URL với danh sách đường dẫn mà loader thực sự cho phép. Tuy nhiên source công khai chỉ tạo điều kiện audit; chất lượng còn phụ thuộc năng lực người kiểm tra, mức độ kiểm thử và việc source có đúng với artifact đang chạy hay không.

Một chuỗi xác minh hữu ích đi từ nguồn tải chính thức, checksum/chữ ký và phiên bản gói, đến hash file thực thi, cấu hình đang có hiệu lực và hành vi HTTP. Hash source/live giúp phát hiện chép nhầm child theme; không tự chứng minh mã không có lỗ hổng. Tương tự, chữ ký hợp lệ chứng minh nguồn/kênh phát hành theo mô hình tin cậy, không chứng minh mọi logic trong bản phát hành đều an toàn. Kho dependency, plugin và dịch vụ cập nhật vẫn là những điểm cần giám sát.

Mã đóng hạn chế khả năng rà soát độc lập toàn bộ source, nhưng không tự đồng nghĩa có mã độc. Có thể đánh giá bằng chữ ký nhà phát hành, chính sách cập nhật, tài liệu kỹ thuật, log và kiểm thử hành vi. Kết luận ATTT cần kết hợp các bằng chứng, tránh dùng nhãn “mã mở” hoặc “mã đóng” như một chứng chỉ an toàn. Bản bàn giao vì vậy giữ source tự viết, cấu hình mẫu không bí mật, test có thể chạy lại và log đã giới hạn dữ liệu, đồng thời nêu rõ những phần chưa kiểm chứng.

Phần 2

Website và tùy biến mã nguồn

2.1 Bài toán và tiêu chí nghiệm thu

Lăng Kính cung cấp không gian trưng bày tác phẩm ảnh/thiết kế, kết hợp xem thư viện công khai với gửi tác phẩm có kiểm duyệt. Khách có thể khám phá theo chủ đề, tác giả hoặc từ khóa; người gửi cần tài khoản phù hợp; Admin/Editor chịu trách nhiệm quyết định xuất bản. Mục tiêu không chỉ là trình bày một lưới ảnh đẹp mà còn duy trì dữ liệu nhất quán từ upload, attachment, tác giả đến trạng thái công khai.

Ranh giới quyền được thiết kế ở phía WordPress. Ẩn nút xuất bản trên giao diện không đủ vì người dùng có thể gọi REST hoặc gửi POST trực tiếp vào wp-admin. Ngược lại, bộ lọc và lightbox là tương tác phía trình duyệt trên danh sách đã được máy chủ giới hạn quyền công khai. Hai nhóm xử lý có vai trò khác nhau: JavaScript hỗ trợ trải nghiệm, còn PHP/capability chịu trách nhiệm cho quy tắc dữ liệu và phân quyền.

Bảng 2.1: Đối chiếu yêu cầu và chức năng hiện có

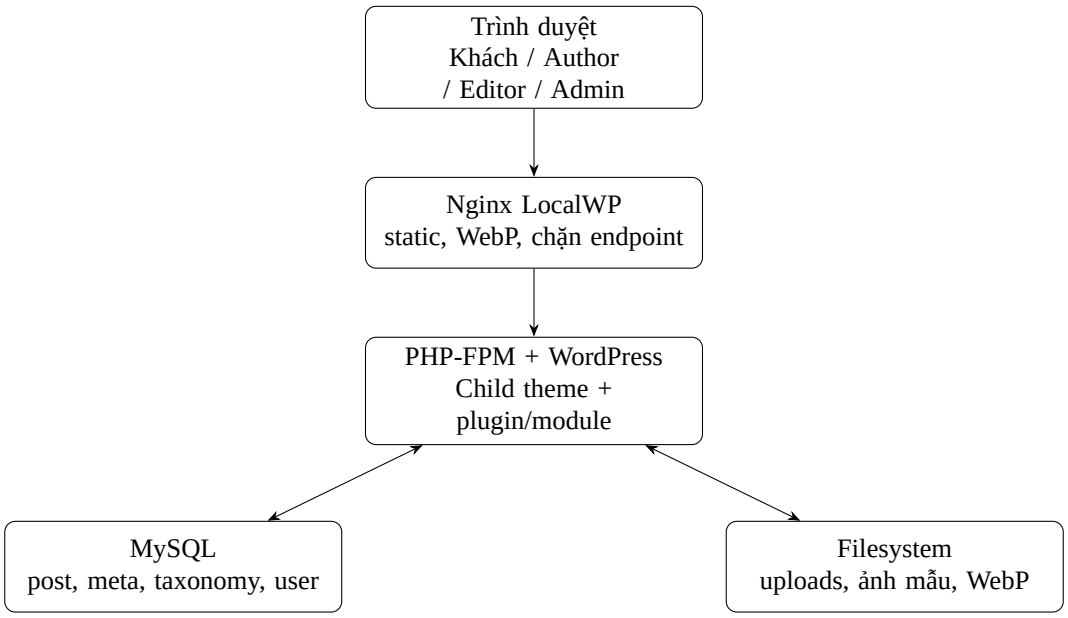
Yêu cầu	Hiện thực	Bằng chứng/giới hạn
Thư viện số	Trang chủ, 30 ảnh mẫu và tác phẩm thật đã duyệt	Hình 2.2; test đếm 30 mẫu khi thêm một bài thật.
Album/chủ đề	Taxonomy lk_topic; album lọc cùng danh sách	Hình 2.4; không tạo bảng DB riêng.
Tác giả	post_author, hiển thị display name và bộ lọc	Bộ lọc “Bộ sưu tập mẫu” vẫn trả 30 ảnh.
Tìm kiếm	Chuẩn hóa tiếng Việt, tìm trong dữ liệu card	Hình 2.5; từ khóa không dấu.
Lightbox	Ảnh lớn, trước/sau, Escape, phím mũi tên	Hình 2.6; danh sách theo bộ lọc đang dùng.
Gửi và duyệt	Shortcode, pending, attachment, featured image	Hai lần gửi tạo hai bài riêng; REST/wp-admin không tự publish.
Watermark	Image Watermark; bộ mẫu đã đóng dấu	Hình 2.10; bản nguồn và backup tách riêng.

Yêu cầu	Hiện thực	Bằng chứng/giới hạn
Tối ưu ảnh	Lazy loading, srcset cho attachment, WebP Nginx	Hình 2.11; kiểm tra MIME và fallback.
An toàn hệ thống	Module riêng + plugin + template Nginx/PHP	Phần 3; không coi cài plugin là đủ.
Mã nguồn và SQL	Child theme, script bàn giao, SQL clone đã ẩn danh	Có import/restore riêng; không phải backup toàn site.

2.2 Môi trường thực hành và kiến trúc

Môi trường được đối chiếu trực tiếp gồm Ubuntu 24.04.4, LocalWP 10.2.0, Nginx 1.26.1, PHP 8.2.29, MySQL 8.4.0 và WordPress 7.1.3. Child theme Lăng Kính 2.4.1 có `Template:astra`; Astra 4.14.1 là theme cha. Đây là phiên bản đã kiểm chứng của môi trường cụ thể, không phải khuyến nghị đóng băng mọi thành phần ở các phiên bản này khi triển khai lâu dài.

Repo chứa phần tự viết và tài sản đi kèm, không chứa WordPress core, Astra vendor hay toàn bộ plugin. File trong IntelliJ chưa phải file được PHP thực thi. Child theme chạy tại `app/public/wp-content/themes/astra-child/`; module bảo mật tại `app/public/wp-content/plugins/lang-kinh-security/`. Template Nginx/PHP của LocalWP nằm ngoài document root, sinh thành runtime sau mỗi Stop/Start. Khi thay code phải copy đúng file, so hash và kiểm tra HTTP; khi chỉ thay tài liệu hoặc sanitizer CLI không cần chép các file đó vào website.



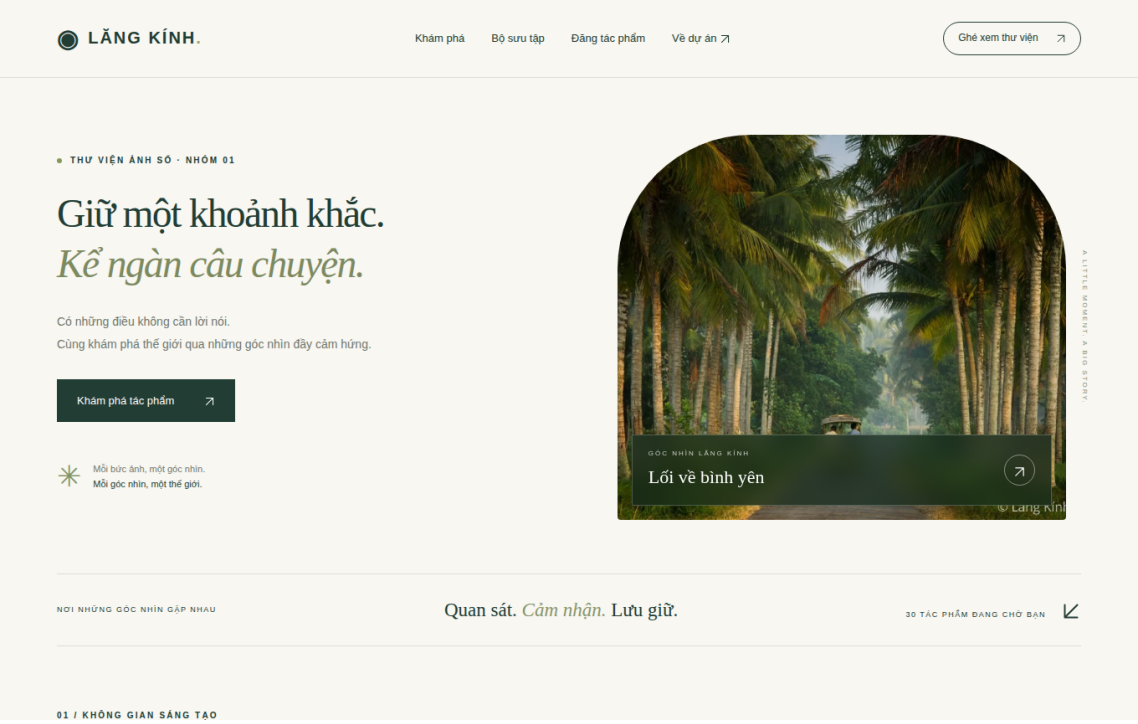
Hình 2.1: Sơ đồ thiết kế kiến trúc do nhóm biên soạn; không phải ảnh chụp hoạt động hay sơ đồ mạng production.

2.3 Trang chủ, banner và responsive

Trang chủ dùng `front-page.php`; CSS của child theme định nghĩa vùng hero, card, album, bộ lọc và các breakpoint. Thiết kế hiện tại được giữ nguyên, không thay Astra hay chuyển sang page builder. Banner

cố định lấy từ cấu hình Customizer trong `inc/hero.php`; khi chưa cấu hình có fallback đến ảnh mẫu đã watermark. Việc thêm bài mới chỉ bổ sung card đầu danh sách, không thay ảnh đại diện nhận diện website.

Người dùng vào trang chủ có thể xem banner, chọn “Khám phá tác phẩm” hoặc chuyển tới album. Mobile thay số cột và kích thước phần tử để tránh cuộn ngang. Kiểm thử tại 390 px và 1440 px kiểm tra chiều rộng document, khả năng decode ảnh và mở lightbox. Kiểm tra bằng ảnh chụp không thay cho việc đo overflow bằng JavaScript, nên cả hai loại bằng chứng được dùng cùng nhau.



Hình 2.2: Trang chủ LocalWP thật, chụp ngày 27/10/2026. Quan sát bố cục hero, banner cố định và liên kết gửi tác phẩm; nguồn: trình duyệt Edge.

2.4 Album, chủ đề và tác giả

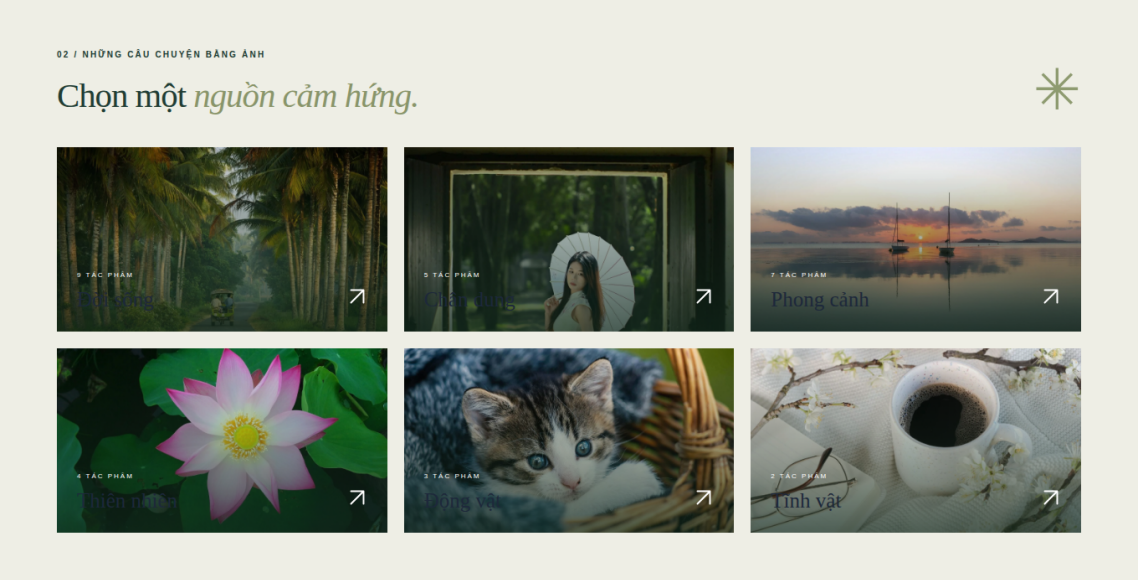


Hình 2.3: Trang chủ ở viewport 390 px trên LocalWP thật. Nguồn: Edge headless; ảnh minh họa kiểm tra responsive, không thay thế kiểm thử trên mọi thiết bị vật lý.

Mỗi tác phẩm là một bài `lk_photo`; chủ đề là taxonomy phân cấp `lk_topic`. Những album trên trang chủ sử dụng cùng các slug chủ đề, nhờ vậy chọn album và chọn chip chủ đề có thể tác động lên cùng tập card. Các chủ đề của ảnh mẫu được khai báo trong catalog và seed có phiên bản, không nhập lại 30 bài mẫu vào DB trên mỗi lượt xem.

Form tải danh sách chủ đề hiện có từ taxonomy. Nếu không chọn, hệ thống dùng "Tự do". Chọn "Khác" yêu cầu tên mới tối đa 80 ký tự; server tìm lại term đã tồn tại trước khi tạo. Term mới chỉ được tạo sau khi ảnh/bài đã lưu hợp lệ, giúp tránh tích lũy term từ request thất bại. Quy tắc này không có nghĩa Author được quản trị tùy ý mọi taxonomy trong wp-admin; đây là hành vi giới hạn trong luồng gửi tác phẩm.

Tác giả của bài thật lấy từ WordPress, không tin tên tác giả tự gửi trong POST. Ảnh mẫu có nhãn riêng "Bộ sưu tập mẫu". Sau khi lọc tác giả mẫu, số card phải luôn là 30 ngay cả khi có bài thật. Với tài khoản bị xóa hoặc đổi tên, quản trị viên cần xử lý quyền sở hữu bằng chức năng WordPress; code không tự thay danh tính tài khoản thật.

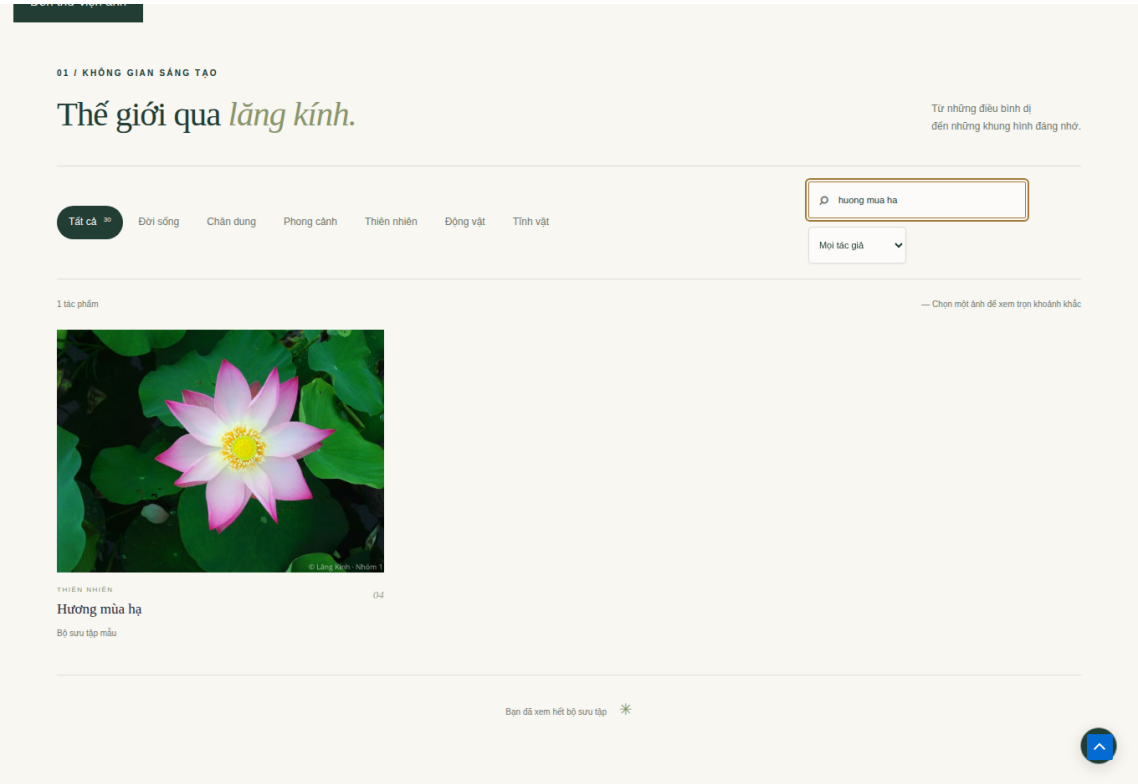


Hình 2.4: Khu vực album trên trang chủ LocalWP. Nguồn: ảnh chụp thật; chọn album dùng cùng cơ chế lọc chủ đề của lưới.

2.5 Tìm kiếm và lightbox

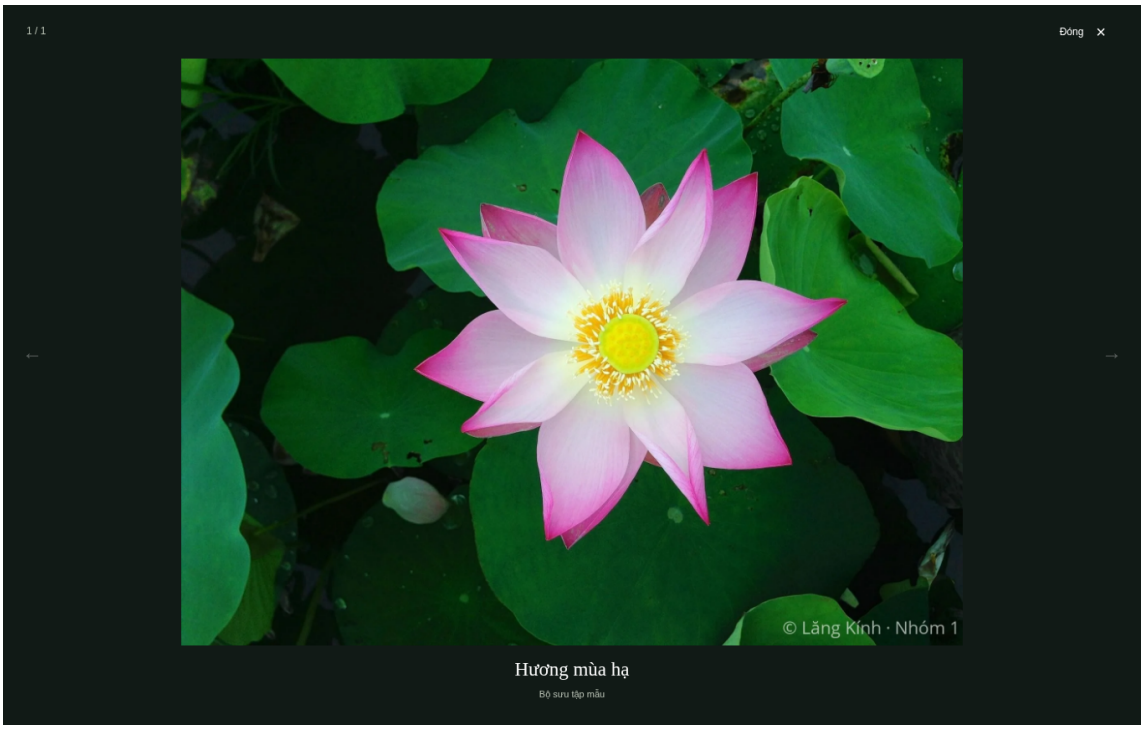
JavaScript trong `js/custom.js` chuẩn hóa chuỗi về chữ thường, loại dấu tổ hợp và xử lý chữ đ/Đ để hỗ trợ từ khóa không dấu. Danh sách card hiện có được lọc theo điều kiện chủ đề, tác giả và từ khóa. Không có request SQL tìm kiếm riêng cho mỗi lần gõ; cách này phù hợp dữ liệu demo nhỏ, nhưng với số lượng lớn cần phân trang/query phía máy chủ thay vì tải toàn bộ bài một lần.

Sau khi lọc, số lượng, trạng thái "không tìm thấy" và các lớp chiều cao card được cập nhật theo những phần tử đang hiển thị. Điều chỉnh CSS focus cho ô tìm kiếm giúp khung không bị lệch khi nhập. Các trạng thái focus bàn phím vẫn được giữ để người dùng nhận biết điều khiển hiện tại. Không dùng việc bỏ toàn bộ outline như giải pháp sửa hình thức.



Hình 2.5: Tìm "huong mua ha" không dấu trên LocalWP trả đúng ảnh "Hương mùa hạ". Nguồn: trình duyệt thật; ảnh quan sát ô nhập, kết quả và bộ lọc.

Lightbox hiển thị ảnh đầy đủ từ thuộc tính dữ liệu của card. Danh sách trước/sau được lấy từ kết quả đang thấy, tránh chuyển sang ảnh đã bị bộ lọc ẩn. Người dùng có thể dùng nút điều hướng, phím mũi tên, Escape hoặc nút đóng; focus được quản lý khi mở/đóng. CSS đã sửa khung vuông trắng ở nút đóng và điều hướng, không thay ảnh gốc để che lỗi giao diện. Kiểm thử còn kiểm tra ảnh trong hộp xem đã decode và không gây overflow mobile.



Hình 2.6: Lightbox LocalWP ở kết quả tìm kiếm. Nguồn: Edge; quan sát nền tối, ảnh lớn và điều khiển đóng/chuyển.

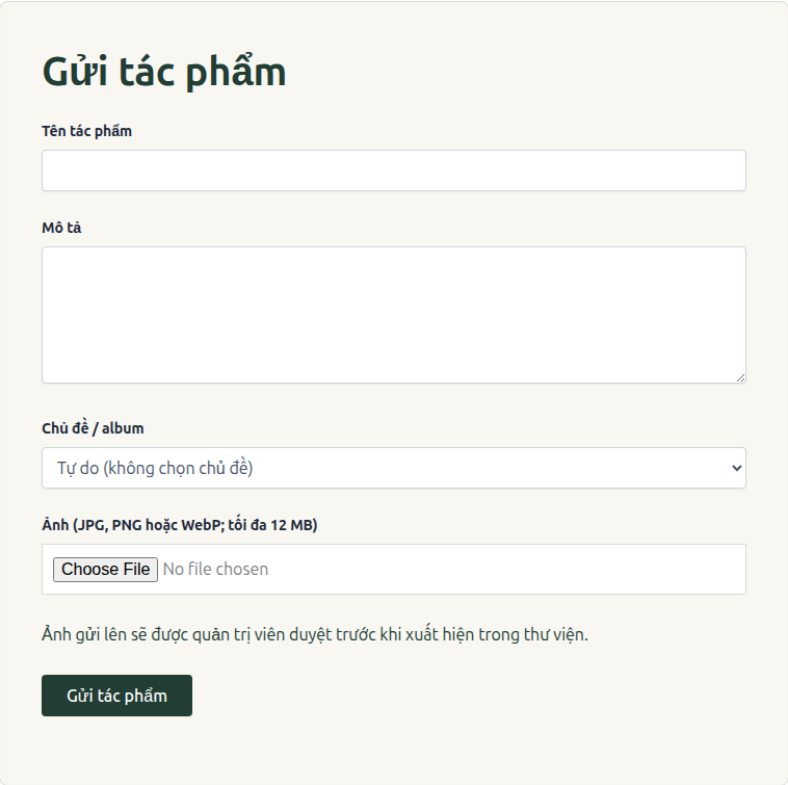
2.6 Gửi tác phẩm và vòng đời dữ liệu

2.6.1 Shortcode và xử lý trước HTML

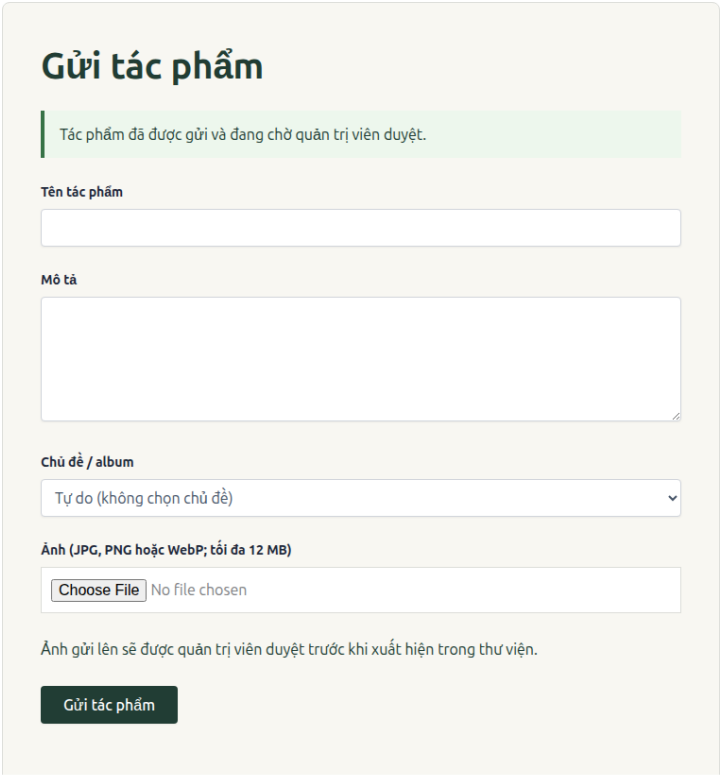
Trang `/dang-tac-pham/` chứa shortcode `[lk_upload_form]`. Shortcode chỉ dựng giao diện; hook `template_redirect` xử lý request trước khi template xuất HTML. Khách nhận liên kết đăng nhập do `wp_login_url` tạo, có đích quay lại form và tự tương thích WPS Hide Login. Người đã đăng nhập nhưng thiếu `upload_files` hoặc `edit_lk_photos` vẫn bị từ chối.

Sau kiểm tra quyền, server xác minh nonce, tiêu đề, chủ đề và file. MIME phải khớp loại ảnh thực từ file tạm, không chỉ dựa vào phần mở rộng hoặc Content-Type do trình duyệt khai. Phần upload dùng API media WordPress, tạo attachment và các kích thước ảnh, sau đó tạo `lk_photo` với status pending và author là tài khoản hiện tại. Thumbnail phải gắn thành công mới được coi là tác phẩm hoàn chỉnh.

Nếu tạo bài, thumbnail hoặc gán chủ đề thất bại, code dọn bài/attachment vừa tạo trong request đó; không xóa ảnh đại diện người dùng đã chọn trước đây. Khi hoàn tất, response 303 chuyển về GET có receipt gắn bài/tài khoản. Thông báo thành công được kiểm tra bằng nonce receipt, owner, status và thumbnail, không chỉ nhìn chuỗi `lk_upload=pending`.



Hình 2.7: Form của tài khoản thử dùng một lần trên LocalWP; các mục chủ đề lấy từ taxonomy. Nguồn: ảnh chụp thật, không phải wireframe.



Hình 2.8: Thông báo sau khi request thực sự lưu thành công bài/ảnh chờ duyệt. Nguồn: LocalWP; dữ liệu thử đã được dọn sau kiểm thử.

2.6.2 Sửa lỗi gửi lần hai và giới hạn PHP

Lỗi cũ xuất hiện khi code ưu tiên tham số GET thông báo trước POST: lần hai gửi từ URL có pending chỉ hiện thành công nhưng không lưu dữ liệu. Bản hiện tại ưu tiên xử lý POST, form action là permalink sạch và sử dụng Post/Redirect/Get. Test gửi hai lần liên tiếp yêu cầu hai ID khác nhau, cùng pending và đều có featured media; chỉ thấy hai thông báo xanh không đủ chứng minh yêu cầu này.

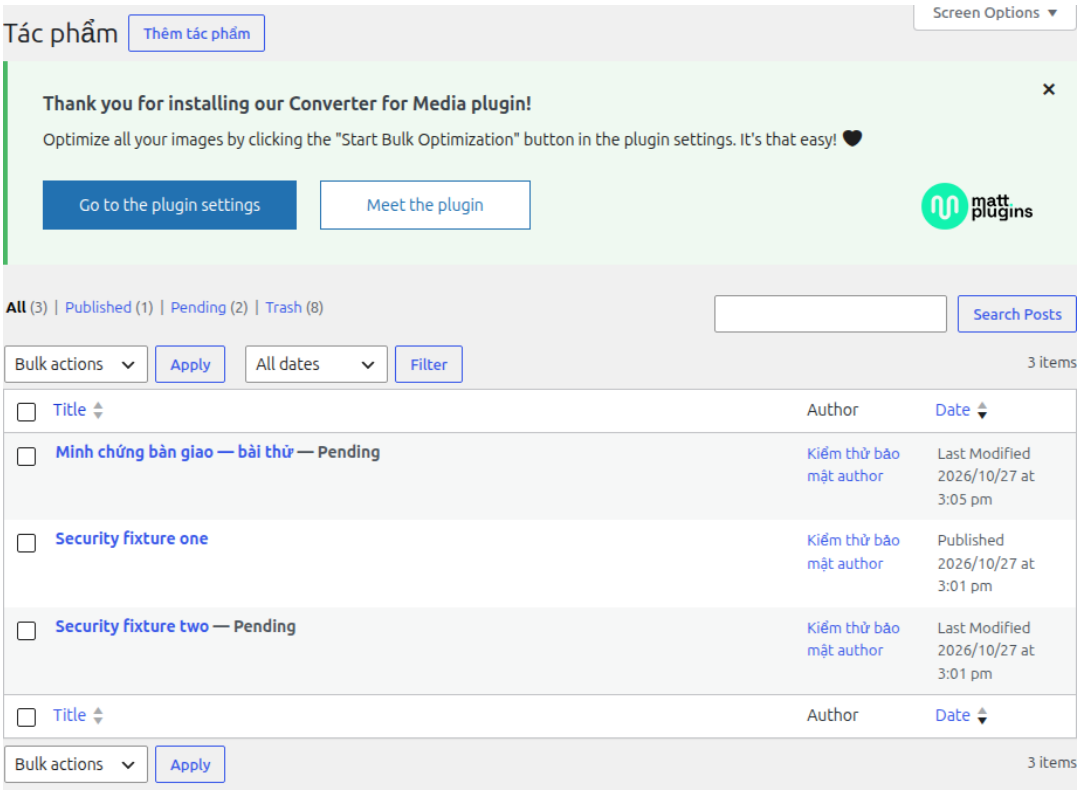
Một lỗi khác xuất hiện trước khi WordPress chạy: PHP có thể làm rỗng cả POST và FILES khi body vượt `post_max_size`. Do đó handler so Content-Length với giới hạn tổng POST trước điều kiện kiểm tra nút submit. K/M/G dùng hệ số nhị phân; 0 hoặc giá trị âm được xử lý là không giới hạn tổng trong helper. Request quá lớn nhận 413 và hướng dẫn nhập lại/chọn ảnh nhỏ hơn, không chuyển thành công. Giới hạn 12 MB của form khác giới hạn tệp PHP và khác giới hạn tổng request.[16]

Trên LocalWP thật đã tạm đặt post limit 16 MB, gửi request 17 MB và nhận 413; sau đó khôi phục đúng template PHP 1000 MB ban đầu và Stop/Start. Tệp 13 MB bị chặn bởi giới hạn form ngay cả khi server cho phép lớn hơn. PHP ghi một cảnh báo do phép thử cố tình vượt giới hạn; đây không phải lỗi fatal trong code. Kết quả được tách khỏi tuyên bố “không có lỗi ngoài dự kiến”.

2.6.3 Phân quyền và duyệt

CPT dùng bộ capability `lk_photo/lk_photos` và `map_meta_cap=true`. Author có quyền tạo/sửa tác phẩm phù hợp nhưng không có publish capability của CPT; Admin/Editor có quyền xem và duyệt pending. Không xóa `publish_posts` trên toàn WordPress vì việc đó làm thay đổi quyền bài viết thông thường ngoài phạm vi thư viện.[17]

Test Author cố tạo publish/future/private qua REST nhận 403, sửa pending thành publish cũng bị chặn; POST vào wp-admin không tự xuất bản được. Editor đọc được bài pending có thumbnail và chuyển publish thành công. Khi đó trang chủ thêm một bài thật trước 30 ảnh mẫu. Một bài draft/pending/trash hoặc không có thumbnail hợp lệ không được đưa vào danh sách công khai.



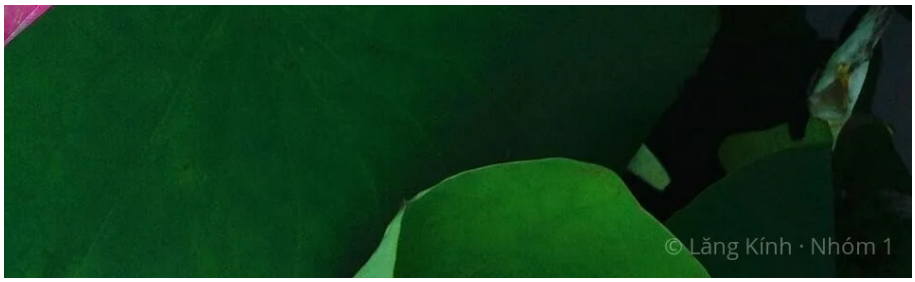
Hình 2.9: Danh sách tác phẩm trong wp-admin của tài khoản kiểm duyệt thử. Nguồn: LocalWP thật; các bài thử minh họa pending và published, không phải nội dung của tài khoản thật.

2.7 Watermark và tối ưu ảnh

2.7.1 Watermark, bản gốc và backup

Image Watermark 2.0.16 được cấu hình tự áp dụng cho ảnh upload, ở frontend và admin theo kích thước được chọn. Nội dung dấu "© Lăng Kính · Nhóm 1" dùng font hỗ trợ tiếng Việt. Plugin có cơ chế backup ảnh trước xử lý; dữ liệu backup nằm ngoài repo và không được nhầm với ảnh đang phục vụ công khai. Khi thay cấu hình watermark phải kiểm tra ảnh đầu ra, tránh chồng nhiều dấu hoặc tạo WebP từ file chưa đóng dấu.

Bộ 30 ảnh mẫu dùng các file đã watermark trong `assets/demo-watermarked/`; bản nguồn giữ riêng và manifest có checksum. Ảnh mẫu không tự trở thành attachment trong DB. Việc đóng watermark không chuyển quyền tác giả của ảnh gốc sang nhóm; hồ sơ nguồn ảnh vẫn là yêu cầu pháp lý/tài liệu còn thiếu. Không dùng dấu của nhóm để khẳng định sở hữu ảnh chưa có chứng cứ.



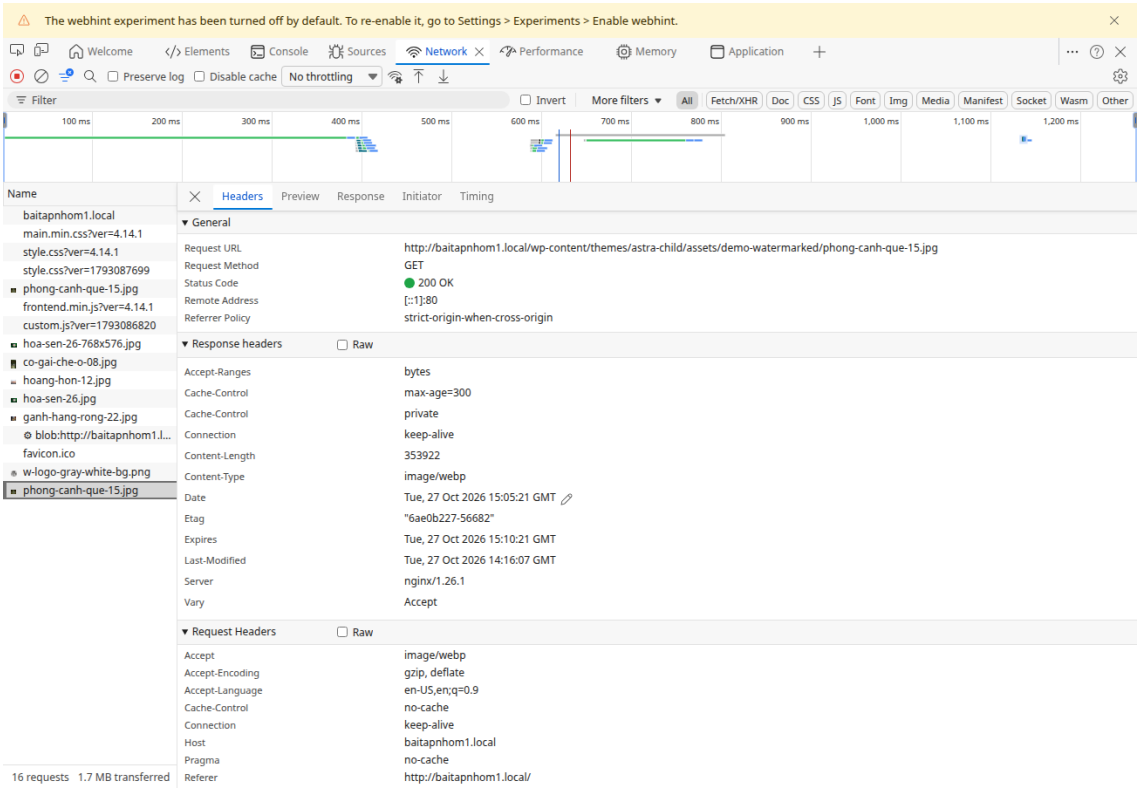
Hình 2.10: Vùng watermark trên WebP của ảnh mới upload trong kiểm thử LocalWP. Nguồn: crop từ file derivative thật; crop chỉ để đọc dấu, không thêm chữ vào ảnh.

Lazy loading trì hoãn tải những card ngoài vùng xem; banner được ưu tiên tải. Bài thật có srcset/sizes do WordPress sinh từ attachment metadata, giúp trình duyệt chọn kích thước phù hợp viewport. Ảnh mẫu hiện dùng file cố định nên không tuyên bố chúng có đầy đủ srcset như attachment. WebP giảm định dạng truyền tải theo khả năng client; không thay thế việc giới hạn kích thước pixel, nén hợp lý hoặc kiểm tra chất lượng.

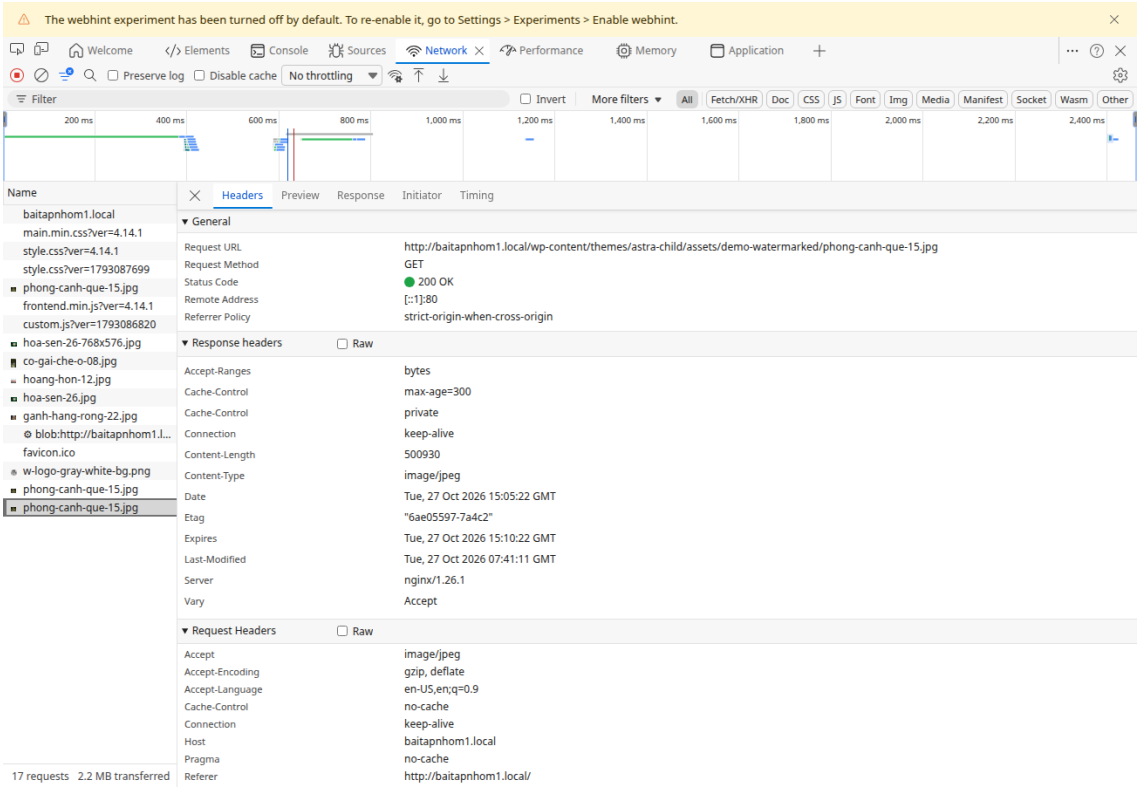
2.7.2 Chẩn đoán và sửa WebP trên Nginx

Converter for Media 6.7.0 trước đây bật Pass Thru với cả uploads và themes. Chẩn đoán thực tế xác nhận URL loader cho ảnh theme trả HTTP 200, Content-Type HTML và body rỗng, trong khi JPG trực tiếp vẫn mở được. Đọc mã plugin cho thấy bộ đổi URL áp dụng cho thư mục themes nhưng allowlist của Pass Thru chỉ map uploads. Vì vậy nguyên nhân được kết luận từ cả HTTP lẫn source; không đoán rằng mọi file JPG đã mất hoặc tự thay phần mở rộng hàng loạt.

Giải pháp hiện tại giữ Converter bật và dùng chế độ rewrite. Tên tùy chọn loader là `htaccess`, nhưng Nginx không đọc file .htaccess; quy tắc tương đương được đặt trong template LocalWP. Snippet nằm trước các regex ảnh/include khác, tìm derivative trong uploads-webpc khi Accept có WebP và fallback về URI gốc nếu không có file. Response có Vary: Accept để cache không nhầm bản JPG và WebP. Cấu hình tham khảo hướng dẫn chính thức của plugin, giới hạn thư mục uploads/themes và không bật AVIF trong đợt này.[18]



Hình 2.11: DevTools Network thật của Edge gắn với LocalWP: cùng URL JPG, response image/webp khi gửi Accept WebP. Nguồn: DevTools trực tiếp, không dựng lại bảng Network.



Hình 2.12: DevTools Network thật khi gửi Accept image/jpeg: URL giữ nguyên, response image/jpeg và Vary: Accept. Nguồn: cùng phiên kiểm chứng LocalWP.

Các trường quan trọng được chép ra bảng để đọc khi in A4; ảnh Network độ phân giải đầy đủ được

giữ trong thư mục figures. Đây là số liệu HTTP thực, không phải bảng giả làm screenshot.

Bảng 2.2: Đối chiếu negotiation cho cùng URL ảnh banner

Trường	Client WebP	Client JPEG
Accept	image/webp	image/jpeg
HTTP / Content-Type	200 / image/webp	200 / image/jpeg
Vary	Accept	Accept
Body	Khớp derivative WebP trên đĩa	Khớp JPG nguồn trên đĩa

Đã kiểm tra 30 ảnh mẫu và 14 biến thể của hai ảnh mới, mỗi file theo hai Accept, tổng 88 request: status, MIME, Vary và body khớp file tương ứng trên đĩa. Khi thiếu derivative, client hỗ trợ WebP vẫn nhận JPG hợp lệ. Ảnh mới có cờ watermark, đầy đủ derivative và dấu còn nhìn thấy trên WebP. Kiểm tra trang sau Stop/Start xác nhận template sinh lại và trình duyệt decode ảnh/banner/lightbox ở desktop/mobile. Không gọi việc chỉ tắt plugin là hoàn tất WebP.

2.8 Tổ chức code tự viết

2.8.1 Nạp tài nguyên và khai báo mô hình

`functions.php` đăng ký theme support, kích thước lk-gallery, enqueue CSS/JS, CPT và taxonomy; phần upload và banner tách sang inc để dễ đọc và kiểm thử. Version tài nguyên dùng mtime của file tự viết; version Astra giữ theo theme cha để cache busting. Không xóa bừa mọi query ver nhằm che dấu phiên bản.

Trích đoạn đang dùng để nạp tài nguyên:

```
add_action( 'wp_enqueue_scripts', function () {
    wp_enqueue_style( 'astra-parent', get_template_directory_uri() . '/style.css', array(), wp_get_theme( 'astra'
    ↪  )->get( 'Version' ) );
    wp_enqueue_style( 'lk-style', get_stylesheet_uri(), array( 'astra-parent' ), filemtime(
    ↪  get_stylesheet_directory() . '/style.css' ) );
    wp_enqueue_script( 'lk-gallery', get_stylesheet_directory_uri() . '/js/custom.js', array(), filemtime(
    ↪  get_stylesheet_directory() . '/js/custom.js' ), true );
} );
```

Trích đoạn cấu hình riêng quyền và liên kết taxonomy:

```
        'map_meta_cap' => true,
        'taxonomies' => array( 'lk_topic' ),
        'public' => true, 'show_in_rest' => true, 'menu_icon' => 'dashicons-format-gallery',
        'supports' => array( 'title', 'editor', 'thumbnail', 'author', 'excerpt' ),
        'rewrite' => array( 'slug' => 'tac-pham' ),
    ) );
    register_taxonomy( 'lk_topic', 'lk_photo', array(
```

Lớp giao diện không cấp quyền dựa trên role name nhận từ client. Phân quyền thực tế dùng capability của WordPress; migration chạy tại init với marker phiên bản, bổ sung quyền và tạo trang còn thiếu ngay cả khi theme đã active từ trước. Nếu trang do người dùng tạo đã tồn tại, code không ghi đè nội dung. Migration chỉ ghi marker hoàn tất khi seed/chức năng tạo trang trả thành công.

2.8.2 Danh sách kết hợp và xử lý lỗi

`lk_gallery_items()` query riêng publish, bỏ qua bài thiếu thumbnail/src, dựng trường tác giả/chủ đề/srcset rồi nối catalog mẫu. Cách này giữ thứ tự bài thật trước và làm số lượng/bộ lọc/lightbox làm việc trên một tập thống nhất. Query không phân trang phù hợp demo; mở rộng production cần xem xét số lượng bài, bộ nhớ và phương pháp tìm kiếm.

Handler upload có đường thoát rõ khi gặp sai nonce, chủ đề, MIME, kích thước hoặc lỗi lưu. Server là lớp bắt buộc, bởi JavaScript có thể bị tắt/bỏ qua. Receipt thành công không cho người dùng đọc tùy ý pending của người khác. Cơ chế dọn chỉ nhắm ID vừa tạo trong cùng luồng, tránh xóa attachment hiện hữu vì một request giả mạo.

Back-to-top và các thao tác menu/scroll được xử lý trong JavaScript của child theme; chúng không thay đổi trạng thái server. Khi người dùng yêu cầu giảm chuyển động, CSS tôn trọng prefers-reduced-motion. Phạm vi kiểm thử giao diện gồm viewport desktop/mobile, trạng thái tìm rỗng, lọc tác giả, album, mở/đóng lightbox và không có lỗi JavaScript ngoài dự kiến.

2.9 Git, thành phần bên thứ ba và license

Nhóm phát triển trên nhánh huyyhoangg, kiểm tra HEAD và working tree trước sửa; không reset toàn repo hoặc sửa lịch sử để gán đóng góp. Repo nộp cuối cần được điền sau khi nhóm tự review. Lượt chuẩn hóa này không tự commit/push/merge; người phụ trách xem diff, chạy test và quyết định commit theo phần việc thực tế. Không tạo commit giả chỉ để đủ năm tên trong danh sách.

Bảng 2.3: Kiểm kê đầy đủ core, theme và plugin cài trên LocalWP

Tên	Phiên bản	Trạng thái	License	Mục đích
WordPress	7.1.3	Core	GPL-2.0-or-later	Nền tảng nội dung
Astra	4.14.1	Theme cha	GPL-2.0-or-later	Theme nền
Lăng Kính Child	2.4.1	Đang dùng	GPL-2.0-or-later	Giao diện/CPT/shortcode
Twenty Twenty-Five	1.5	Không active	GPL-2.0-or-later	Theme mặc định
Twenty Twenty-Four	1.6	Không active	GPL-2.0-or-later	Theme mặc định
Twenty Twenty-Three	1.7	Không active	GPL-2.0-or-later	Theme mặc định
Image Watermark	2.0.16	Active	MIT	Watermark/backup ảnh
Converter for Media	6.7.0	Active, rewrite	GPL-2.0-or-later	WebP Nginx/fallback
Wordfence Security	9.0.2	Active, Basic	GPL-3.0-or-later	WAF; không xác nhận Premium
LLAR	3.3.10	Active, free/local	GPL-2.0-or-later	Giới hạn đăng nhập
WPS Hide Login	1.9.19	Active	GPL-2.0-or-later	URL đăng nhập riêng
Lăng Kính Security	1.0.0	Active	GPL-2.0-or-later	Module nhóm tự viết

Nguồn kiểm chứng: header style.css của từng theme; header/readme của plugin đã cài; directory chính thức WordPress.org. Bảng không có key/license token. Bản miễn phí và trạng thái active không đồng nghĩa có quyền Premium. Xem PLUGIN-LICENSES.md để tra URL nguồn từng gói.[19]

WordPress/Astra/plugin chính thức được cài ngoài repo từ nguồn tương ứng. Module `security/l`

`ang-kinh-security/` và child theme là phần nhóm quản lý, không phải phiên bản sửa của vendor. LICENSE MIT gốc vẫn giữ nguyên thông báo hiện hữu; phạm vi GPL được ghi ở header các thành phần riêng. Hồ sơ license phải được rà lại khi cập nhật gói, vì inventory ghi nhận thời điểm khảo sát, không phải chứng nhận vĩnh viễn.

Phần 3

ATTT và bảo mật hệ thống

3.1 Mô hình đe dọa và phạm vi

Tài sản cần bảo vệ gồm tài khoản quản trị, tác phẩm chờ duyệt, file ảnh, cấu hình kết nối và tính toàn vẹn website. Những đường vào chính là đăng nhập, upload, REST/wp-admin, endpoint WordPress và plugin. Đối tượng kiểm tra là website LocalWP do nhóm quản lý; không quét GitHub, website ngoài nhóm hay brute-force tài khoản thật. Kiểm thử local không mô phỏng đầy đủ TLS, reverse proxy và các đe dọa Internet của production.

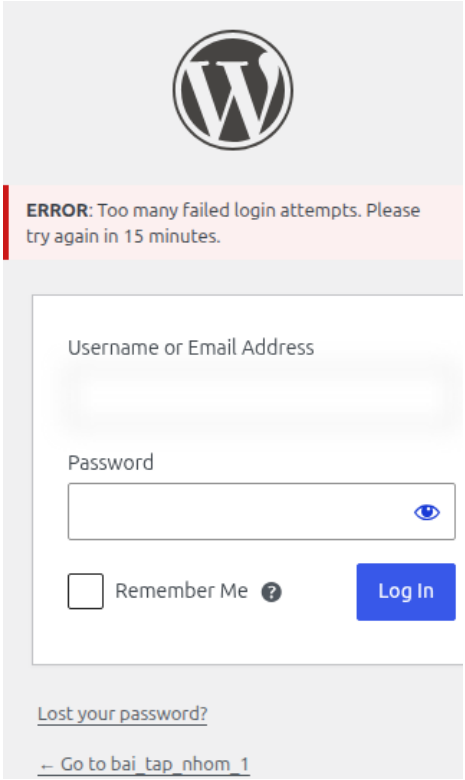
Hardening giảm bề mặt và hậu quả của lỗi, còn vulnerability assessment thu thập dấu hiệu để đánh giá rủi ro. Chặn XML-RPC không chứng minh plugin không có lỗi; WAF chặn scanner không phải chứng minh mọi khai thác đều bị chặn. Báo cáo phân biệt rõ trạng thái plugin, cấu hình đã lưu và hành vi được xác nhận qua HTTP.[20]

3.2 Bảo vệ tài khoản và khôi phục

3.2.1 URL đăng nhập và giới hạn thử sai

WPS Hide Login chuyển endpoint đăng nhập bằng cơ chế WordPress hỗ trợ; không đổi tên vật lý wp-login.php/wp-admin. Liên kết đăng nhập, đăng xuất, quên mật khẩu và đích quay về upload được tạo qua API WordPress. Giá trị slug thật không nằm trong repo hay báo cáo. URL mới làm giảm request tự động vào endpoint mặc định, nhưng không phải yếu tố xác thực thứ hai và không thay mật khẩu mạnh.

LLAR là limiter đang phụ trách thử sai: 5 lần trong cửa sổ 900 giây, khóa 900 giây; 4 đợt khóa dẫn đến khoảng khóa dài hơn 3600 giây. Trên LocalWP, nhiều phiên có thể cùng hiện dưới loopback. Vì vậy test dùng tài khoản thử, chụp snapshot trạng thái limiter trước, không thử mật khẩu sai với tài khoản quản trị thật và phục hồi đúng snapshot sau test. Kiểm chứng cho thấy lần thứ năm bị khóa, mật khẩu đúng của tài khoản thử cũng bị từ chối trong thời gian khóa, rồi truy cập lại được sau thao tác phục hồi có kiểm soát.



Hình 3.1: Ảnh khóa đăng nhập thật từ hồ sơ kiểm thử LocalWP; trường tài khoản đã che. Ảnh lịch sử được giữ cùng log hồi quy; không phải thử sai với admin thật.

Khi quên URL, owner có thể dùng Site Shell lấy tùy chọn whl_page hoặc vô hiệu riêng WPS Hide Login bằng CLI, sau đó cấu hình lại. Khi bị khóa, quản trị viên xác minh nguyên nhân và mở khóa qua CLI theo hướng dẫn, không đặt tác vụ tự xóa bộ đếm định kỳ. Nếu cần đổi tên thư mục plugin để phục hồi, chỉ đổi thư mục plugin; không đổi core. Khôi phục phải giữ phiên quản trị đang có hoặc đường CLI để tránh tự khóa người vận hành.

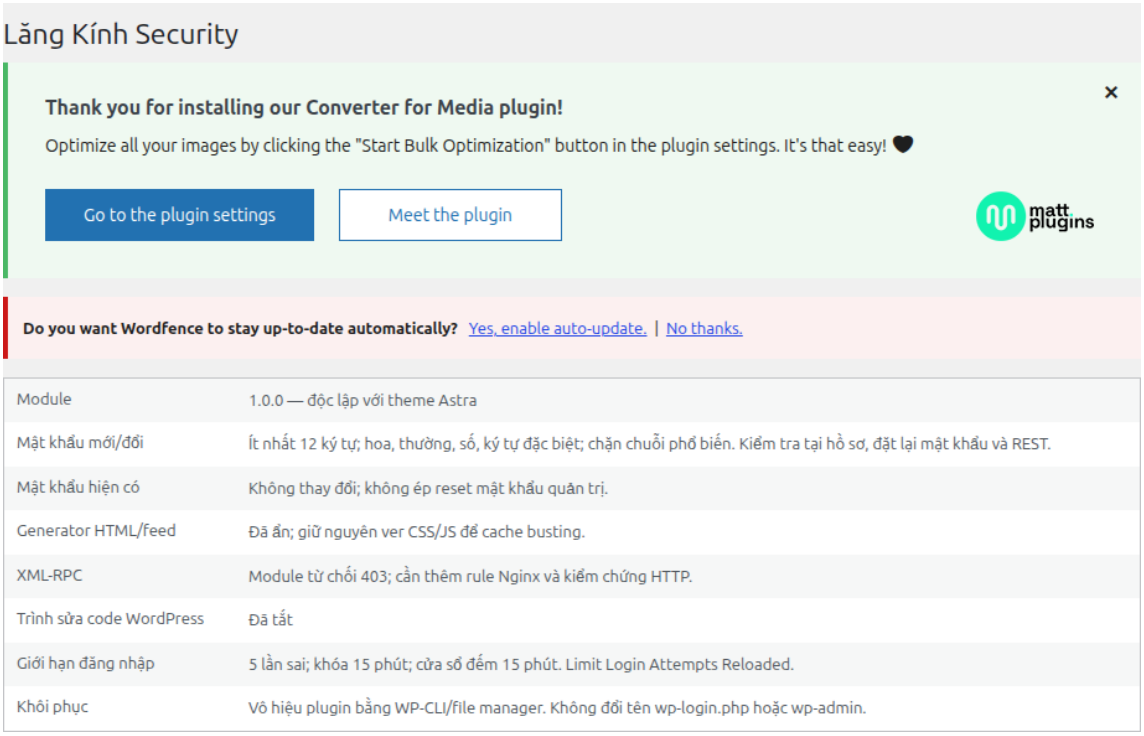
3.2.2 Chính sách mật khẩu và Wordfence

Module Lăng Kính Security kiểm tra mật khẩu mới/đổi ở hồ sơ, reset và REST: tối thiểu 12 ký tự, chữ hoa, thường, số, ký tự đặc biệt; từ chối một số chuỗi phổ biến. Không tự đổi mật khẩu quản trị hiện hữu. Kiểm tra ở REST callback boundary trả WP_Error trước khi cập nhật; việc đặt error sai loại vào filter chuẩn bị object là một lỗi từng được sửa. Đường CLI/programmatic tin cậy được giữ để khôi phục, nên không tuyên bố mọi plugin gọi trực tiếp API PHP đều chịu cùng policy.

Wordfence 9.0.2 đang active, có key và onboarding hoàn tất; WAF ở Enabled/Basic Protection. Basic chạy trong bối cảnh WordPress, không được gọi là Extended Protection. Hai thành phần login/password tương ứng của Wordfence được tắt để tránh trùng với LLAR/module. Cần phân biệt key hiện diện với giấy phép trả phí: báo cáo không có bằng chứng quyền sử dụng Premium và không nhận là đã quét malware đầy đủ.[21]

3.3 Hardening ứng dụng và máy chủ

Module bảo mật tách khỏi theme để chính sách không biến mất khi đổi giao diện. Các hook loại generator HTML/feed, bỏ X-Pingback, thêm nosniff và referrer policy, từ chối XML-RPC ở lớp WordPress và vô hiệu file editor. Việc ẩn generator chỉ giảm một nguồn fingerprint; query ver của tài nguyên vẫn được giữ để cache busting. Header router LocalWP có thể còn báo phiên bản Nginx, vì thế không tuyên bố đã giấu toàn bộ dấu vết công nghệ.



Hình 3.2: Màn hình Lăng Kính Security trên LocalWP trong đợt bàn giao. Nguồn: ảnh chụp mới bằng tài khoản thử; đây là trạng thái cấu hình, hành vi còn được kiểm tra bằng HTTP.

Nginx có `autoindexoff` và exact location chặn XML-RPC, readme, wp-config, trình cài đặt/setup không cần sau cài. Rule đặt trong template `conf/nginx/...hbs`, không chỉ .htaccess và không chỉ runtime. PHP tắt display_errors, display_startup_errors, expose_php, giữ log_errors. Sau Stop/Start phải so lại runtime và status HTTP; một rule trong repo chưa triển khai không phải bằng chứng site đã được hardening.

Quyền thư mục/file được áp dụng trong application root sau khi xác minh owner và tài khoản chạy dịch vụ. wp-config thực tế là 400, PHP vẫn đọc được; thư mục 755, file ứng dụng 644, dữ liệu Wordfence có file 600. Plugin tạo file mới có thể chịu umask riêng, cần theo dõi derivative. LocalWP từng tạo helper debug rộng hơn sau Start; module chỉ sửa đúng helper trong môi trường local, không chmod toàn home. Upload và watermark được chạy lại để kiểm tra không bị hỏng do quyền.

Bảng 3.1: Đối chiếu trạng thái, cấu hình và hành vi bảo mật

Thành phần	Đã bật/lưu	Kiểm chứng hành vi	Giới hạn
WPS Hide Login	Active, slug riêng	Login/logout và quay về upload	Không thay xác thực đa yếu tố.
LLAR	5 lần / 15 phút	Khóa lần 5, phục hồi truy cập	IP local dùng chung; test đã hoàn nguyên bộ đếm.
Policy mật khẩu	Module active	REST/profile từ chối yếu; reset có log lịch sử	Không ép đổi mật khẩu cũ; CLI là đường tin cậy.
Nginx hardening	Template + runtime	XML-RPC và thư mục trả 403	Không đại diện cho cấu hình router production.
Wordfence	Enabled/Basic, có key	Scanner UA mặc định từng bị 403	Không chứng minh Extended, Premium hay malware scan.

3.4 Đánh giá lỗ hổng và lịch sử WPScan

3.4.1 Nguồn dữ liệu và các lần chạy

Hồ sơ có các lần WPScan 3.8.28 không token do công cụ chạy trước đây, một lần bị WAF chặn và lần Docker 4.1.0 có API do người dùng cung cấp. Không gộp các log thành một lần quét mới. Bản 4.1.0 báo Started/Finished ngày 27/10/2026 nhưng console không in timezone; không tự quy đổi thời gian đó thành UTC. Các mốc UTC của 3.8.28 lấy từ trường timestamp trong JSON.

Bảng 3.2: Các lần WPScan và giới hạn đọc kết quả

Lần chạy	Số liệu	Diễn giải
3.8.28 trước	09:14:45–09:16:22 UTC; 690 request, 11 cache	Không có vulnerability API. Exit 0 ghi trong hồ sơ cũ; sanitizer cũ từng suy mã thoát nên cần runner gốc nếu tái xác minh exit.
3.8.28 bị chặn	UA mặc định; HTTP 403; hồ sơ ghi exit 4	Scan aborted; không coi là scan sạch hay hoàn tất.
3.8.28 retry sau	10:43:31–10:45:26 UTC; 712 request, cache 0	Random UA, không tắt WAF. Không có API; không suy WAF Enabled chỉ từ UA.
Docker 4.1.0	12:18:16–12:18:24 theo console; 15 request, 9 cache	Người dùng thực hiện. API Free OK, dùng 3, còn 19; exit không được capture độc lập qua pipeline tee.

Lệnh Docker được trình bày bỏ token thực và không chứa login riêng:

```
docker run --rm --network host \
  --add-host=baitapnhom1.local:127.0.0.1 \
  -e WPSCAN_API_TOKEN wpscanteam/wpscan \
  --url http://baitapnhom1.local --random-user-agent \
  --enumerate vp,vt --detection-mode passive \
  --plugins-detection passive
```

Token phải được truyền bằng cơ chế riêng trên máy, không chép giá trị vào lệnh lưu Git. Muốn lưu exit thật của pipeline Bash cần lấy PIPESTATUS của WPScan ngay sau pipeline, hoặc dùng runner subprocess.returncode. Mã thoát tee không đại diện mã thoát scanner.[22]

Docker retry không nhận diện phiên bản core, không phát hiện plugin bằng passive và nhận diện Astra 4.14.1 với confidence 80%. "No plugins Found" không có nghĩa site không cài plugin. Inventory filesystem xác nhận các plugin thực tế, nên đánh giá độ phủ phải đối chiếu cả hai nguồn. Metadata WPScan lúc đó ghi latest Astra 4.14.0 trong khi nhận diện 4.14.1; không tự hạ cấp theme hoặc tự gán lỗi từ bất nhất metadata.

3.4.2 Bảng đánh giá có căn cứ

Bảng 3.3: Cảnh báo cấu hình, bằng chứng và xử lý

Phát hiện	Bằng chứng	Lớp	Mức/căn cứ	Khắc phục	Sau xử lý
Author tự publish	REST từng trả 201 publish	Theme	High đối với quy trình duyệt; không gán CVE	CPT capability riêng, migration	REST 403; wp-admin không publish.
XML-RPC mở	Trước GET 405, scanner thấy endpoint	Server / core	Medium: RPC không dùng, mở bề mặt auth	Nginx 403 + module fallback	Sau Stop/Start vẫn 403.
Quyền config rộng	Hồ sơ baseline 664, root 775	Server	Medium: có thể lộ DB secret cho user local	Root 755, file 644, config 400	PHP đọc được, upload thành công.
Thiếu limiter/policy	Inventory và test baseline	Plugin / auth	Medium: thiếu lớp giảm thử sai	LLAR + policy module	Khóa lần 5; REST/profile yếu bị chặn.
Generator / readme	HTML/feed và phát hiện scanner trước	Core / server	Low: nhận diện, chưa có exploit	Hook generator, chặn endpoint	Feed/meta mất generator; ver CSS/JS giữ.
Directory browsing	Baseline đã 403	Server	Thông tin; phòng ngừa	autoindex off tường minh	HTTP vẫn 403; không khẳng định từng lộ listing.
WAF chỉ Basic	Trạng thái cấu hình firewall	Plugin	Thông tin: giới hạn chế độ	Giữ Basic, không sửa vendor	Không tuyên bố Extended.
Server header	Router vẫn có thể lộ nginx	Server	Low: hỗ trợ nhận diện	server_tokens site, tắt expose PHP	Chưa ẩn mọi header router.
API / coverage thiếu	3.8.28 thiếu token; Docker passive trống	Quy trình	Medium về thiếu bằng chứng, không phải CVE	Đối chiếu từng slug/version với dữ liệu cập nhật	API OK chưa đủ phủ toàn inventory.
Pass Thru theme	200 HTML, body rỗng; JPG mở được	Plugin / server	Thông tin: lỗi chức năng, không phải CVE	Rewrite Nginx + WebP marked	WebP/fallback HTTP đúng.

Mức trong bảng thể hiện rủi ro trong bối cảnh ứng dụng hoặc cấu hình, không phải điểm CVSS tự tính. Không có bằng chứng xác nhận khai thác CVE hoặc xâm nhập trong phạm vi này. Robots/WP-Cron

là endpoint tiêu chuẩn từng được tool liệt kê; chưa có bằng chứng DoS nên không tắt bừa, tránh hỏng scheduler/chuyển ảnh.

3.4.3 Sanitizer, bảo vệ log và giới hạn còn lại

Sanitizer hiện yêu cầu tool version, argv, exit thực và SHA-256 raw trong metadata đã xác minh. Input rỗng/sai schema bị từ chối; exit thiếu ghi unknown; scan aborted tách riêng. Timestamp giữ theo raw, không đổi thời gian chạy cũ thành thời điểm biên soạn báo cáo. Random user-agent không được dùng để suy trạng thái WAF. Các báo cáo lịch sử được giữ nguyên và có chú thích về giới hạn công cụ cũ, không tái tạo metadata giả.

Trong đợt bàn giao phát hiện regex che Authorization cũ có thể chỉ che chữ Bearer rồi để lại credential. Bản sửa che toàn bộ giá trị header Authorization/Proxy-Authorization/Cookie trên dòng đó. Test gồm Bearer, Basic, Negotiate, cookie nhiều phần và kiểm tra dòng Server tiếp theo còn nguyên. Đây là test tổng hợp bảo vệ tính riêng tư của script, không phải bằng chứng đã khai thác token thật. Chín nhóm test sanitizer đã qua trước khi xuất dữ liệu mới.

Không có ảnh console WPScan mới được dựng lại từ text để giả một lần chạy. Console retry thật dạng text và JSON đối chiếu được dẫn ở hồ sơ repo. Nếu cần ảnh toàn cửa sổ terminal do giảng viên yêu cầu, người quản lý cần chụp lần chạy thật hoặc mở log lịch sử với nhãn rõ ràng, che host/token. Không có kết quả ZAP/Nmap, không có pentest Internet, và không kết luận "không có lỗ hổng" từ passive scan thiếu độ phủ API.

3.5 Lập trình an toàn và hồi quy

Sanitization dùng đúng ngữ cảnh nhập: text cho tiêu đề/choice, textarea cho mô tả; validation xác nhận term thuộc taxonomy, giới hạn độ dài, upload error và MIME thực. Khi dựng HTML dùng esc_html, esc_attr, esc_url, esc_textarea. Nonce chống CSRF đi cùng capability; nonce đơn lẻ không cấp quyền. WordPress xử lý truy vấn/lưu bài qua API thay vì ghép SQL từ request.

Hai đoạn ngắn sau lấy trực tiếp từ handler hiện tại, thể hiện quyền và nonce là hai kiểm tra độc lập; đây là trích đoạn, không phải toàn bộ hàm:

```
nocache_headers();
if ( ! is_user_logged_in() || ! current_user_can( 'upload_files' ) || ! current_user_can( 'edit_lk_photos' ) )
↪  {
    return;
}


if ( 'POST' === $method && isset( $_POST['lk_upload_submit'] ) ) {
    $nonce = isset( $_POST['lk_upload_nonce'] ) ? sanitize_text_field( wp_unslash( $_POST['lk_upload_nonce'] )
    ↪  ) : '';
    if ( ! wp_verify_nonce( $nonce, 'lk_upload_photo' ) ) {
        $notice = 'Phiên gửi biểu mẫu đã hết hạn. Hãy tải lại trang và thử lại.';
    } else {
        $title = isset( $_POST['lk_photo_title'] ) ? sanitize_text_field( wp_unslash( $_POST['lk_photo_title']
        ↪  ) ) : '';
        $description = isset( $_POST['lk_photo_description'] ) ? sanitize_textarea_field( wp_unslash(
        ↪  $_POST['lk_photo_description'] ) ) : '';
```

Request upload chỉ tạo dữ liệu sau kiểm tra cần thiết; trạng thái pending được đặt server-side. Quyền

riêng CPT còn bảo vệ qua REST/wp-admin nên một trường status giả không vượt kiểm duyệt. Lỗi lưu có cleanup và lỗi quá POST-limit nhận thông báo thay vì thành công giả. Đầu ra thông báo được escape, không đưa tên file độc hại vào HTML thô.

Bảng 3.4: Kết quả kiểm thử và mức bằng chứng

Nhóm kiểm tra	Kết quả quan sát	Trạng thái
Upload / duyệt	Hai ID pending; Editor publish; Author bị từ chối publish	Passed LocalWP
Input không hợp lệ	Guest/thiếu quyền, nonce sai, JPEG giả, 13 MB bị từ chối	Passed LocalWP
POST-limit	17 MB vượt PHP tạm 16 MB, HTTP 413; đã khôi phục template	Passed đợt sửa lỗi
WebP và UI	MIME/Vary/body; watermark; filter/search/album/lightbox/mobile	Passed LocalWP
Login/hardening	URL riêng, logout, lần sai thứ 5, XML-RPC/directory 403	Passed LocalWP
SQL restore	Import DB thứ hai; media, taxonomy, serialized data, admin mới	Passed môi trường riêng
Sanitizer	9 nhóm test schema/exit/API/redaction/metadata	Passed tổng hợp
CVE toàn inventory	Chưa có dữ liệu API đối chiếu đủ từng thành phần	Chưa xác minh
ZAP/Nmap/production	Không thực hiện trong phạm vi	Unrun

Không phát hiện lỗi JavaScript ngoài dự kiến trong lượt hồi quy; kiểm tra cú pháp PHP/JS qua. Dữ liệu thử dùng tài khoản dùng một lần và được dọn; hash tác phẩm gốc, thumbnail, mật khẩu và theme mods được so để phát hiện thay đổi ngoài phạm vi. Kiểm thử không chứng minh mọi thiết bị/trình duyệt hoặc mọi định dạng ảnh đều không có lỗi. Những hạn chế đó cần đi cùng kết quả passed để người nhận hiểu đúng mức bảo đảm.

Phần 4

Bàn giao, WBS và hướng phát triển

4.1 Phạm vi bộ mã nguồn bàn giao

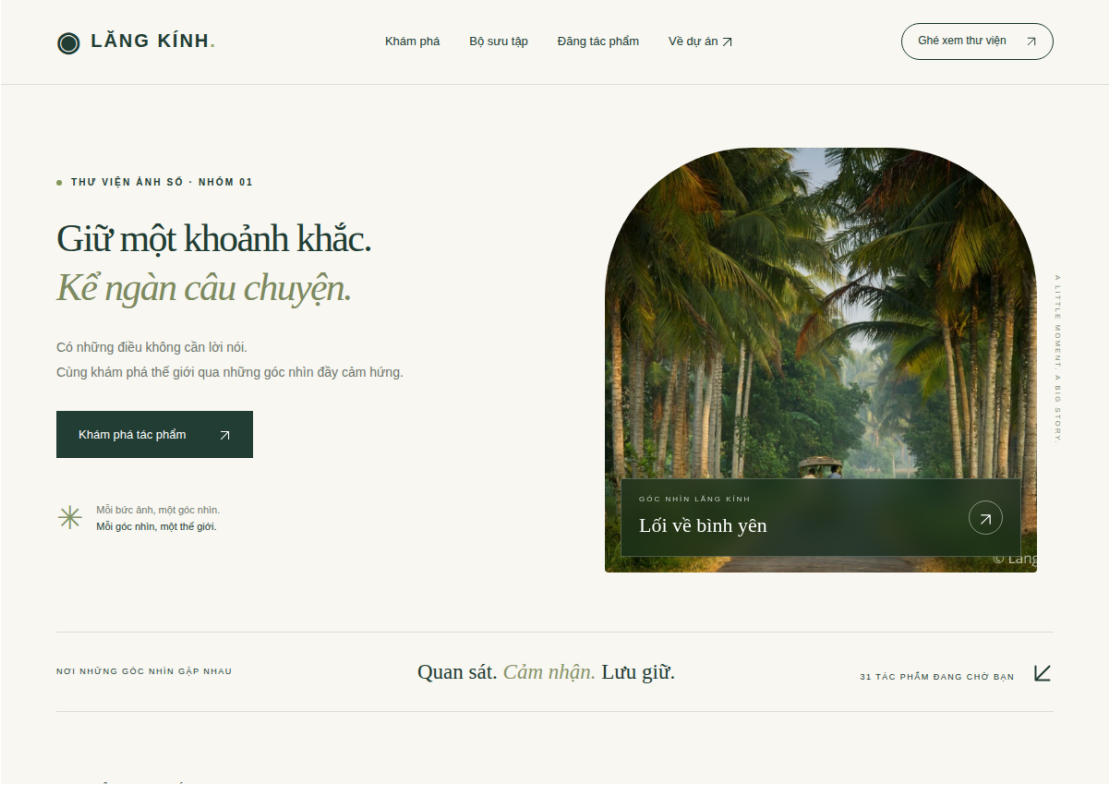
Bộ nộp gồm child theme, các file PHP/CSS/JS tự viết, module bảo mật, snippet Nginx, script hỗ trợ, SQL demo sạch và hướng dẫn khôi phục. Không di chuyển hàng loạt inc/assets hoặc thay đường dẫn đang dùng. WordPress core, Astra và plugin vendor được người nhận cài riêng từ nguồn chính thức. Không đưa wp-config.php, backup thật, SQL gốc, key Wordfence hay URL đăng nhập riêng vào bộ nộp.

SQL được tạo từ clone database LocalWP thực tế. Site chính giữ tài khoản/tác phẩm/banner; thao tác làm sạch chỉ thực hiện trong DB clone. Clone bỏ bảng log/plugin chứa cấu hình nhạy cảm, xóa session/reset data và thay danh tính người dùng bằng tác giả demo. Các dòng user_pass chứa marker vô hiệu, không phải hash tài khoản thật và không có mật khẩu mặc định công khai.

Các tác phẩm cũ trên site nguồn đang ở thùng rác, không có bài lk_photo đã xuất bản tại thời điểm trích xuất. SQL giữ quan hệ cần thiết của phần dữ liệu được chọn và bổ sung hai bài publish/pending chỉ trên clone, có tiêu đề/nội dung ghi rõ tính minh họa. Những attachment có thể là ảnh chụp riêng được thay trong clone bằng ảnh demo đã có trong repo; ID quan hệ được giữ, metadata được tạo lại đúng file thay thế. Không gọi các dữ liệu bổ sung đó là hoạt động thật của người dùng site chính.

4.2 Khôi phục đã kiểm chứng và khác biệt môi trường

Bản thử khôi phục chạy WordPress qua PHP development server trên loopback, không phải Nginx LocalWP của site chính. Quy trình kiểm chứng tạo database thứ hai trống, import đúng SQL xuất từ clone, đổi URL bằng WP-CLI search-replace có hỗ trợ serialized data, rồi phục hồi media từ manifest. Môi trường restore không chép uploads gốc; file demo được lấy từ đường dẫn repo có SHA-256 và sinh lại các kích thước WordPress. Kiểm tra cho thấy 9 attachment hợp lệ, ít nhất 7 chủ đề, một tác phẩm công khai cùng đủ 30 mẫu và dữ liệu serialized đọc được. Đăng nhập HTTP sau tạo admin mới được kiểm tra riêng.



Hình 4.1: Website từ database khôi phục riêng sau import và phục hồi media. Nguồn: môi trường kiểm thử độc lập; ảnh này không được dùng làm bằng chứng cấu hình thành công trên LocalWP chính.

SQL không chứa toàn bộ dữ liệu nhị phân ảnh. Bộ demo hiện tái sử dụng ảnh đã có trong child theme qua manifest để tránh đưa screenshot/upload riêng tư vào repo. Với nội dung thật cần bàn giao về sau, phải xuất media được phép sử dụng, giữ đường dẫn tương đối và metadata phù hợp, đồng thời có hồ sơ nguồn/quyền. Không sao chép toàn bộ iw-backup hoặc wflogs rồi coi là media công khai.

Trên máy khác, người nhận tạo database/config/salt mới, cài dependency và tạo tài khoản admin qua Site Shell. Wordfence cần key/onboarding riêng; LLAR cần kiểm tra IP thật nếu có proxy; WPS cần slug riêng mới; watermark cần font và kích thước đầu ra; Nginx phải include snippet đúng vị trí và được Start/Stop. SQL cố ý không mang theo các secret/cấu hình cấp phép của máy nguồn. Hướng dẫn chi tiết nằm tại docs/installation/README.md và database/README.md.

4.3 WBS và phân công đề xuất

Năm thành viên được gán mã TV1–TV5, mục tiêu khoảng 20% mỗi người. Đây là tỷ trọng đề xuất để tổ chức công việc, không phải số giờ đã đo hoặc cam kết đóng góp được xác nhận. Các đầu ra trong repo đã có một phần hoặc được chuẩn hóa trong đợt này; người thực hiện và commit tương ứng vẫn phải được nhóm xác nhận bằng lịch sử thật. Không sửa author hoặc tạo commit giả để khớp WBS.

Bảng 4.1: WBS đề xuất cho 5 thành viên, khoảng 20% mỗi người

Mã	Đầu việc	TV	Đầu ra	Phụ thuộc	Tiêu chí nghiệm thu	Trạng thái
1.1	Môi trường, inventory	TV1	Phiên bản, đường dẫn	Không	Đúng repo/site, phân biệt runtime	Có đầu ra*

Mã	Đầu việc	TV	Đầu ra	Phụ thuộc	Tiêu chí nghiệm thu	Trạng thái
1.2	SQL sạch và restore	TV1	SQL, manifest, README	1.1	Clone thật, import riêng, không secret	Có đầu ra*
1.3	Kernel và khung LaTeX	TV1	Phần kernel, main.tex	1.1	Citation, PDF build được	Có đầu ra*
2.1	Giao diện, banner	TV2	Child theme, ảnh UI	1.1	Giữ Astra, không thay banner tự động	Có đầu ra*
2.2	Album, filter, search, lightbox	TV2	JS/CSS, test UI	2.1	Không dấu, bàn phím, mobile	Có đầu ra*
2.3	So sánh phân quyền OS	TV2	Nội dung Phần 1	1.1	Giải thích file/thư mục, ACL	Có đầu ra*
3.1	Upload và pending	TV3	Handler, test request	2.1	Hai lần gửi, MIME/size/cleanup	Có đầu ra*
3.2	Watermark/WebP	TV3	Snippet, ảnh Network	3.1	Mark còn nguyên, MIME/fallback đúng	Có đầu ra*
3.3	Quản lý bản vá	TV3	Nội dung Phần 1	1.1	OS khác runtime/WordPress	Có đầu ra*
4.1	Hardening/account	TV4	Module, config, ảnh	1.1	Login/lockout/XML-RPC kiểm chứng	Có đầu ra*
4.2	Lập trình an toàn	TV4	Review code/capability	3.1	Nonce + quyền, Author không publish	Có đầu ra*
4.3	GPL/thương mại	TV4	Nội dung license	1.1	Không đánh đồng Ubuntu/mã/ảnh	Có đầu ra*
5.1	WPScan/sanitizer	TV5	Log sạch, test script	4.1	Không giả exit/API/WAF, che header	Có đầu ra*
5.2	Hồi quy tích hợp	TV5	Test và đối chiếu	2.2, 3.2, 4.2	Passed/unrun tách rõ, giữ dữ liệu	Có đầu ra*
5.3	Auditability, biên tập	TV5	Citation, license, PDF QA	1.3–5.2	Không lỗi tham chiếu, ảnh, font hoặc tràn bảng	Có đầu ra*

*Có đầu ra trong bộ bàn giao, **chưa xác nhận thành viên nào đã thực hiện**. Nhóm cần điền người, commit/test/tài liệu thực tế sau review. Không coi các mục có đầu ra là năm người đã đóng góp đều nhau.

Mỗi thành viên nên review đầu ra phụ thuộc trước khi nhận phần tiếp theo, tự viết nội dung phụ trách và đính kèm test/ảnh thực tế. TV1 quản lý khung biên dịch không có nghĩa viết thay toàn báo cáo. TV5 kiểm tra tính nhất quán không được thay nguồn log cũ bằng kết quả giả mới. Commit nhỏ theo công việc giúp đối chiếu thay đổi với test và bảo toàn tác giả thật.

4.4 Hạn chế và hướng phát triển

Một số tiêu đề album còn có độ tương phản chưa đồng đều trên ảnh nền; chưa đánh giá hoặc tuyên bố đạt WCAG. Bộ demo phù hợp trình diễn cục bộ nhưng chưa có kiểm thử tải lớn, production TLS hoặc đầy đủ CVE trên mọi thành phần. Truy vấn toàn bộ tác phẩm có thể cần phân trang; tìm kiếm client cần thay đổi khi thư viện lớn. Chính sách mật khẩu là lớp kiểm tra tối thiểu, chưa tương đương đánh giá mật khẩu rò rỉ hoặc triển khai MFA. Basic WAF cũng không thay thế vá phần mềm.

Hồ sơ nguồn/quyền của từng ảnh cần được nhóm bổ sung trước công bố rộng. Khi có dữ liệu thật được phép bàn giao, có thể xây gói media riêng có checksum thay vì dùng ảnh thay thế. Các ảnh cấu hình và log lịch sử cần được gắn thời gian; ảnh mới nên chụp sau khi thay plugin/config. Quản trị viên phải tự

điền thông tin học phần và xác nhận WBS, repo nộp cuối, đóng góp cá nhân.

Các cải tiến tiếp theo nên theo trình tự kiểm kê–backup–clone–thử–review–triển khai. Bộ mã hiện không tự push, merge hoặc deploy lên website công khai. Việc bàn giao có ý nghĩa khi người nhận có thể phục hồi, kiểm tra kết quả và hiểu rõ phần nào được chứng minh, thay vì chỉ nhận một giao diện chụp đẹp hoặc một file SQL không rõ nguồn gốc.

Tài liệu tham khảo

[1] Canonical. Ubuntu 26.04.1 lts release and release lifecycle. https://releases.ubuntu.com/26.04/. Đối chiếu ngày 27/10/2026; bản .1 phát hành 27/08/2026.

[2] Canonical. Ubuntu release cycle. https://ubuntu.com/about/release-cycle. Truy cập 27/10/2026.

[3] Linux man-pages project. System calls and linux capabilities. https://man7.org/linux/man-pages/man2/syscalls.2.html. Tài liệu giao diện kernel; truy cập 27/10/2026.

[4] Linux Kernel Project. Building external modules. https://docs.kernel.org/kbuild/modules.html. Truy cập 27/10/2026.

[5] Microsoft. User mode and kernel mode. https://learn.microsoft.com/en-us/windows-hardware/drivers/gettingstarted/user-mode-and-kernel-mode. Truy cập 27/10/2026.

[6] Microsoft. Windows kernel-mode executive support library. https://learn.microsoft.com/en-us/windows-hardware/drivers/kernel/windows-kernel-mode-executive-support-library. Truy cập 27/10/2026.

[7] Linux man-pages project. acl(5): Access control lists. https://man7.org/linux/man-pages/man5/acl.5.html. Truy cập 27/10/2026.

[8] Microsoft. Access tokens. https://learn.microsoft.com/en-us/windows/win32/secauthz/access-tokens. Truy cập 27/10/2026.

[9] Microsoft. Access control lists. https://learn.microsoft.com/en-us/windows/win32/secauthz/access-control-lists. Truy cập 27/10/2026.

[10] Canonical. Automatic updates and unattended-upgrades. https://ubuntu.com/server/docs/how-to/software/automatic-updates/. Truy cập 27/10/2026.

[11] Microsoft. Windows update client policies. https://learn.microsoft.com/en-us/windows/deployment/update/windows-update-client-policies. Truy cập 27/10/2026.

[12] Microsoft. Windows 11 release information. https://learn.microsoft.com/en-us/windows/release-health/windows11-release-information. Vòng đời theo edition/feature release; truy cập 27/10/2026.

[13] Linux Kernel Project. Linux kernel licensing rules. https://www.kernel.org/doc/html/latest/process/license-rules.html. GPL-2.0-only và ngoại lệ syscall; truy cập 27/10/2026.

[14] Canonical. Intellectual property rights policy. https://canonical.com/legal/intellectual-property-policy. Phạm vi thành phần/nhãn hiệu; truy cập 27/10/2026.

[15] Microsoft. Microsoft software license terms. https://www.microsoft.com/useterms. Điều khoản phụ thuộc bản Windows và kênh cấp phép; truy cập 27/10/2026.

[16] PHP Documentation Group. Description of core php.ini directives. https://www.php.net/manual/en/ini.core.php. post_max_size, upload_max_filesize; truy cập 27/10/2026.

[17] WordPress.org. register_post_type. https://developer.wordpress.org/reference/functions/register_post_type/. capability_type, map_meta_cap; truy cập 27/10/2026.

[18] matt plugins. Configuration for nginx server. https://mattplugins.com/docs/nginx-configuration. Quy tắc phục vụ derivative, Accept và Vary; truy cập 27/10/2026.

[19] WordPress.org. Plugin directory: official distributions. https://wordpress.org/plugins/. Slug cụ thể và giấy phép được đối chiếu thêm với header/readme gói đã cài.

[20] WordPress.org. Hardening wordpress. https://developer.wordpress.org/advanced-administration/security/hardening/. Truy cập 27/10/2026.

[21] Wordfence. Web application firewall. https://www.wordfence.com/help/firewall/. Basic/Extended Protection; truy cập 27/10/2026.

[22] WPScan. Wpscan user documentation. https://github.com/wpscanteam/wpscan/wiki/WPScan-User-Documentation. Passive detection và vulnerability API; truy cập 27/10/2026.